

UNIT IV

MasterCard/Visa Secure Electronic Transaction: Introduction – Business Requirements – Concepts – Payment processing – E-mail and secure e-mail technologies for electronic commerce. Introduction – The Mean of Distribution – A model for message handling – Working of Email - MIME: Multipurpose Internet Mail Extensions – S/MIME: Secure Multipurpose Internet Mail Extensions – MOSS: Message Object Security Services.

1. BUSINESS REQUIREMENTS

a. What are the seven major business requirements addressed by SET?(7) Dec '08

There are seven major business requirements addressed by SET :

1. Provide confidentiality of payment information and enable confidentiality of order information that is transmitted along with the payment information
2. Ensure integrity for all transmitted data
3. Provide authentication that a cardholder is a legitimate user of a branded payment card account
4. Provide authentication that a merchant can accept branded payment card transactions through its relationship with an acquiring financial institution.
5. Ensure the use of the best security practices and system design techniques to protect all legitimate parties of an electronic commerce transaction.
6. Ensure the creation of a protocol that is neither dependent on transport security mechanisms nor prevents their use.
7. Facilitate and encourage interoperability across software and network providers.

2. CONCEPTS

(b) Point out the features of the business requirements specification and explain each in detail. (8) Dec '08

The business requirements are addressed by the following features of these specifications

Confidentiality of information

Integrity of data

Cardholder account authentication

Merchant authentication

Interoperability

Confidentiality of information:

Assurance to cardholders that their payment information is safe and accessible only by the intended recipient.

Cardholder account and payment information must be secured as it travels across the network, preventing interception of account numbers and expiration dates by unauthorized individuals.

Confidentiality is ensured by the use of message encryption**Integrity of data**

The specification must guarantee that message content is not altered during the transmission between originator and recipient.

Payment information sent from cardholders to merchants includes order information, personal data and payment instructions.

If any component is altered in transit, the transaction will not be processed accurately.

In order to eliminate this potential source of fraud and/or error, SET must provide the means to ensure that the contents of all order and payment messages received match the contents of messages sent.

Payment information integrity is ensured by the use of digital signature**Cardholder account authentication:**

Merchants need a way to verify that a cardholder is a legitimate user of a valid branded payment card account number.

A mechanism that uses technology to link a cardholder to a specific payment card account number will reduce the incidence of fraud and therefore the overall cost of payment processing

These specifications define the mechanism to verify that a card holder is legitimate user of a valid payment card account number.

Card holder account authentication is ensured by the use of digital signatures and cardholder certificates.

Merchant authentication:

The specifications must provide a way for cardholders to confirm that merchant has a relationship with a financial institution allowing it to accept payment cards.

Cardholders also need to be able to identify merchants with whom they can securely conduct electronic commerce.

Merchant authentication is ensured by the use of digital signatures and merchant certificates

Interoperability:

The specification must be applicable on a variety of hardware and software platforms and must include no preference for one over another.

Any cardholder with compliant software must be able to communicate with any merchant software that also meets the defined standard

Interoperability is ensured by the use of specific protocols and message formats

3. Payment System Participant

Point out the participants of payment system. (10) (Nov '10) (May '10)
--

Interaction of participants

SET changes the way that participants in the payment system interact. In a face to face retail transaction or a mail order transaction, the electronic processing of the transaction begins with the merchant or the Acquirer. However, in an SET transaction, the electronic processing of the transaction begins with the cardholder.

Cardholder

In the electronic commerce environment, consumers and corporate purchasers interact with the merchants from personal computers. A card holder uses a payment card that has been issued by an issuer.

SET ensures that the interactions the cardholder has with a merchant keep the payment card account information confidential.

Issuer

An issuer is the financial institution that establishes an account for a cardholder and issues the payment card. The issuer guarantees payment for authorized transactions using the payment card in accordance with payment card brand regulations and local legislation.

Merchant

A merchant offers goods for sale or provides services in exchange for payment. SET allows a merchant to offer electronic interactions that cardholders can use securely. A merchant that accepts payment cards must have a relationship with an acquirer.

Acquirer

An acquirer is the financial institution that establishes an account with a merchant and processes payment card authorizations and payments.

Payment gateway

A payment gateway is a device operated by an acquirer or a designated third party that processes merchant payment messages (including payment instructions from cardholders)

Brand

Financial institutions have founded bankcard associations that protect and advertise the brand, establish and enforce rules for use and acceptance of their bankcards, and provide networks to interconnect the financial institutions.

Other brands are owned by financial services companies that advertise the brand and establish and enforce rules for use and acceptance of their payment cards. These brands combine the roles of Issuer and Acquirer in interactions with cardholders and merchants.

Third parties

Issuers and Acquirers sometimes choose to assign the processing of payment card transactions to third party processors. This document does not distinguish between the financial institution and the processor of the transactions.

What are the two primary encryption methods?

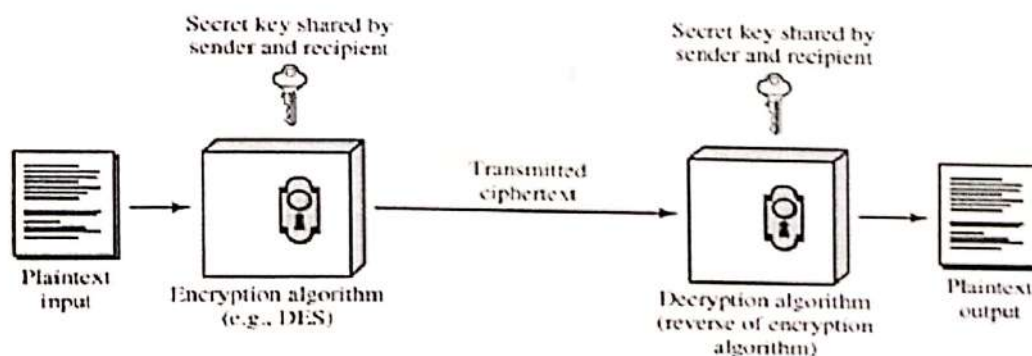
(5) Nov '10

Encryption can be done using private key or public key

Conventional encryption / symmetric key encryption:

- Symmetric encryption is a form of cryptosystem in which encryption and decryption are performed using the same key. It is also known as conventional encryption.
- Symmetric encryption transforms plaintext into cipher text using a secret key and an encryption algorithm. Using the same key and a decryption algorithm, the plaintext is recovered from the cipher text.
- The two types of attack on an encryption algorithm are cryptanalysis, based on properties of the encryption algorithm, and brute-force, which involves trying all possible keys.
- Traditional (pre computer) symmetric ciphers use substitution and/or transposition techniques. Substitution techniques map plaintext elements (characters, bits) into cipher text elements. Transposition techniques systematically transpose the positions of plaintext elements.
- Rotor machines are sophisticated pre computer hardware devices that use substitution techniques.
- Steganography is a technique for hiding a secret message within a larger one in such a way that others cannot discern the presence or contents of the hidden message.

Symmetric Cipher Model:



Simplified Model of Conventional Encryption

Public key encryption

- **public-key/two-key/asymmetric** cryptography involves the use of **two keys**:

- a **public-key**, which may be known by anybody, and can be used to **encrypt** messages, and **verify signatures**
- a **private-key**, known only to the recipient, used to **decrypt messages**, and **sign** (create) **signatures**

➤ is **asymmetric** because

- those who encrypt messages or verify signatures **cannot** decrypt messages or create signatures

➤ Public-Key algorithms rely on two keys where:

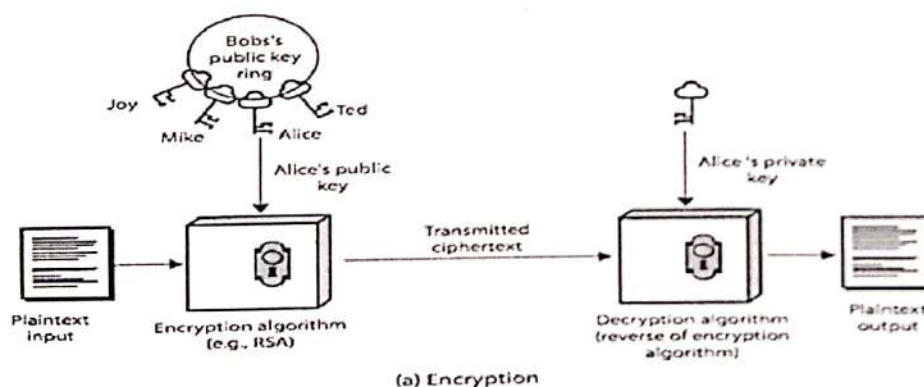
- it is computationally infeasible to find decryption key knowing only algorithm & encryption key
- it is computationally easy to en/decrypt messages when the relevant (en/decrypt) key is known
- either of the two related keys can be used for encryption, with the other used for decryption (for some algorithms)

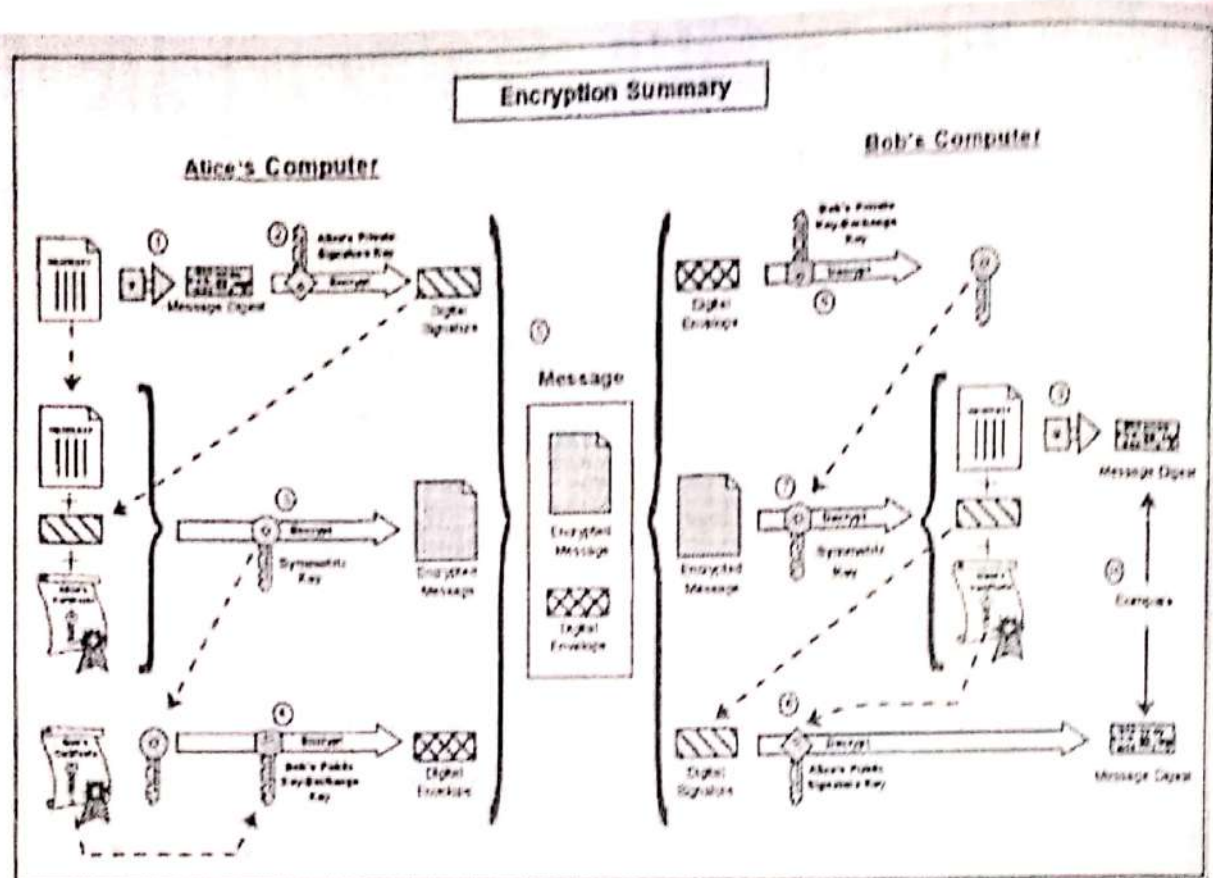
Public-Key Applications

➤ can classify uses into 3 categories:

- **encryption/decryption** (provide secrecy)
- **digital signatures** (provide authentication)
- **key exchange** (of session keys)

➤ some algorithms are suitable for all uses, others are specific to one





Encryption

The encryption process of the diagram on the previous page consists of the following steps:

Step	Description
1	Alice runs the property description through a one-way algorithm to produce a unique value known as the message digest. This is a kind of digital fingerprint of the property description and will be used later to test the integrity of the message.
2	She then encrypts the message digest with her private signature key to produce the digital signature.
3	Next, she generates a random symmetric key and uses it to encrypt the property description, her signature, and a copy of her certificate, which contains her public signature key. In order to decrypt the property description, Bob will require a secure copy of this random symmetric key.
4	Bob's certificate, which Alice must have obtained prior to initiating secure communication with him, contains a copy of his public key-exchange key. To ensure secure transmission of the symmetric key, Alice encrypts it using Bob's public key-exchange key. The encrypted key, referred to as the digital envelope, is sent to Bob along with the encrypted message itself.
5	Finally, she sends a message to Bob consisting of the following: the symmetrically encrypted property description, signature and certificate, as well as the asymmetrically encrypted symmetric key (the digital envelope).

Decryption

Likewise, the decryption process consists of the following steps:

Step	Description
6	Bob receives the message from Alice and decrypts the digital envelope with his private key exchange key to retrieve the symmetric key.
7	He uses the symmetric key to decrypt the property description, Alice's signature and her certificate.
8	He decrypts Alice's digital signature with her public signature key, which he acquires from her certificate. This recovers the original message digest of the property description.
9	He runs the property description through the same one-way algorithm used by Alice and produces a new message digest of the decrypted property description.
10	Finally, he compares his message digest to the one obtained from Alice's digital signature. If they are exactly the same, he confirms that the message content has not been altered during transmission and that it was signed using Alice's private signature key.
If they are not the same, then the message either originated somewhere else or was altered after it was signed. In that case, Bob takes some appropriate action such as notifying Alice or discarding the message.	

SET (Secure Electronic Transaction) is a very comprehensive security protocol, which utilizes cryptography to provide confidentiality of information, ensure payment integrity, and enable identity authentication.

For authentication purposes, cardholders, merchants, and acquirers will be issued digital certificates by their sponsoring organizations.

It relies on cryptography and digital certificate to ensure message confidentiality and security. Digital envelope is widely used in this protocol.

Digital envelope

Message data is encrypted using a randomly generated key that is further encrypted using the recipient's public key. This is referred to as the "digital envelope" of the message and is sent to the recipient with the encrypted message. The recipient decrypts the digital envelope using a private key and then uses the symmetric key to unlock the original message.

Digital certificates

Digital certificates, which are also called electronic credentials or digital Ds, are digital documents attesting to the binding of a public key to an individual or entity. Both cardholders and merchants must register with a *certificate authority* (CA) before they can engage in transactions. The cardholder thereby obtains electronic credentials to prove that he is trustworthy. The merchant similarly registers and obtains credentials.

These credentials do not contain sensitive details such as credit card numbers. Later, when the customer wants to make purchases, he and the merchant exchange their credentials. If both parties are satisfied then they can proceed with the transaction. Credentials must be renewed every few years, and presumably are not available to known fraudsters.

SET Cryptography

Overview

Secure Electronic Transactions (SET) relies on the science of cryptography – the encoding and decoding messages. There are two primary encryption methods in use today: secret-key cryptography and public-key cryptography.

Secret-key cryptography is impractical for exchanging messages with a large group of previously unknown correspondents over a public network. For a merchant to conduct transactions securely with millions of subscribers, each consumer would need a distinct key assigned by that merchant and transmitted over a separate secure channel. However, by using public-key cryptography, that same merchant could create a public/private key pair and publish the public key, allowing any consumer to send a secure message to that merchant. This is why SET uses both methods in its encryption process. The secret-key cryptography

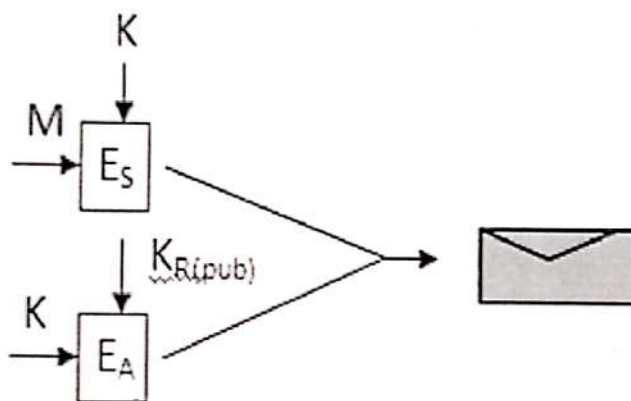
used in SET is the well known Data Encryption Standard (DES), which is used by financial institutions to encrypt PINs (personal identification numbers). And the public-key cryptography used in SET is RSA.

Use of Symmetric Key

Digital envelope :

In SET, message data is encrypted using a randomly generated symmetric key (a DES 56-bit key). This key, in turn, is encrypted using the message recipient's public key (RSA).

The result is the so called "digital envelope" of the message.



K is a random session key and E_s is a symmetric encryption algorithm and E_A is an asymmetric encryption algorithm. The receiver recovers the secret key from the digital envelope using his/her private key. He/she then uses the secret key to decrypt the message.

This combines the encryption speed of DES with the key management advantages of RSA public-key encryption.

After encryption, the envelope and the encrypted message itself are sent to the recipient.

After receiving the encrypted data, the recipient decrypts the digital envelope first using his or her private key to obtain the randomly generated symmetric key and then uses the symmetric key to unlock the original message.

This level of encryption, using DES, can be easily cracked using modern hardware.

Use of Asymmetric Key

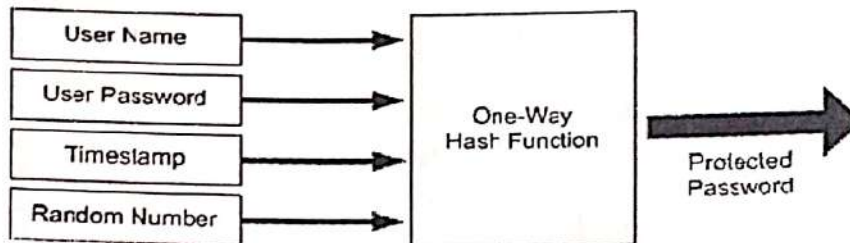
Digital signature : Integrity and authentication are ensured by the use of digital signatures

Digital signatures: relationship of keys

The sender of a message encrypts it using sender's private key.

Any recipient can determine that the message came from the sender by decrypting the message using the sender's public key.

Digital Signature using Message Digests



- A message digest is a value generated by passing the message through a one way cryptographic function, ie., one that cannot be reversed.
- When the digest of a message is encrypted using the sender's private key and appended to the original message, the result is known as the digital signature of the message
- The recipient of the digital signature can be sure that the message really came from the sender.
- The recipient can be sure that the message was not changed after the message digest was generated.

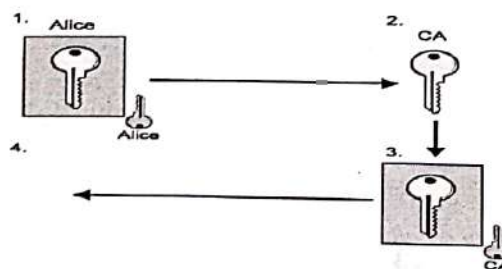
Certificates :

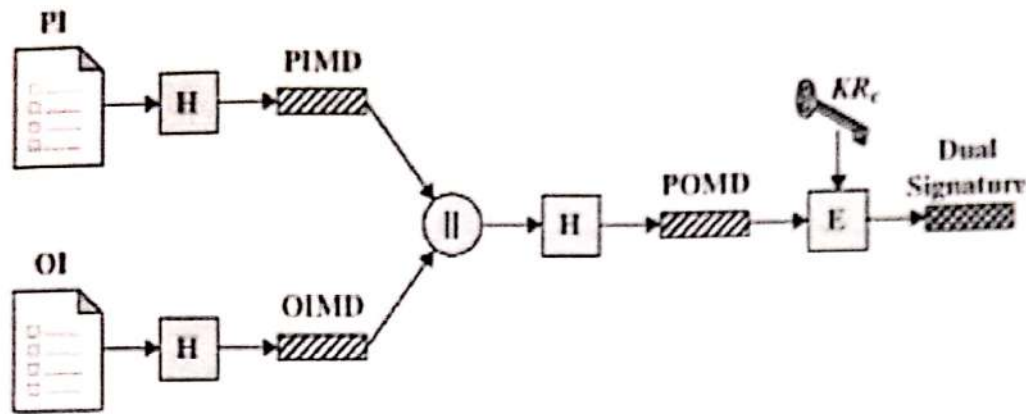
Authentication is further strengthened by the use of certificates.

Before two parties use public-key cryptography to conduct business, each wants to be sure that the other party is authenticated. One way to be sure that the public key belongs to the right party is to receive it over a secure channel directly from the same place. However, in most circumstances this solution is not practical.

An alternative to secure transmission of the key is to use a trusted third party to authenticate that the public key belongs to Alice. Such a party is known as a *Certificate Authority (CA)*.

Because SET participants have two key pairs, they also have two certificates. Both certificates are created and signed at the same time by the Certificate Authority.





PI = Payment Information
 OI = Order Information
 H = Hash function (SHA-1)
 || = Concatenation
 PIMD = PI message digest
 OIMD = OI message digest
 POMD = Payment Order message digest
 E = Encryption (RSA)
 KR_c = Customer's private signature key

1. Alice generates A_{priv} , A_{pub} and AID; Signs $\{A_{pub}, AID\}$ with A_{priv}
 Proves Alice holds corresponding A_{priv}
 Protects $\{A_{pub}, AID\}$ en route to CA
2. CA verifies signature on $\{A_{pub}, AID\}$
 Verifies AID offline (optional)
3. CA signs $\{A_{pub}, AID\}$ with CA_{priv}
 Creates certificate
 Certifies binding between A_{pub} and AID
 Protects $\{A_{pub}, AID\}$ en route to Alice
4. Alice verifies $\{A_{pub}, AID\}$ and CA signature
 Ensures CA didn't alter $\{A_{pub}, AID\}$
5. Alice and/or CA publishes certificate

Dual signature

A new application of digital signatures is introduced in SET, namely the concept of dual signatures. Dual signatures is needed when two messages are need to be linked securely but only one party is allowed to read each. The following picture shows the process of generating dual signatures.

In SET, dual signatures are used to link an order message sent to the merchant with the payment instructions containing account information sent to the acquirer (merchant bank). When the merchant sends an authorization request to the acquirer, it includes the payment instructions sent to it by the cardholder and the message digest of the order information. The acquirer uses the message digest from the merchant and computes the message digest of the payment instructions to check the dual signatures.

Explain the different kinds of cryptographic functions

Encryption

Confidentiality is ensured by the use of message encryption.

Encryption : relation of keys

When two users want to exchange messages securely, each transmits one component of their key pair, designated the public key, to the other and keeps secret the other component, designated the private key.

SECURITY

Purpose of Security:

1. Data Confidentiality – is provided by encryption/decryption.
2. Authentication and Identification – ensuring that someone is who he or she claims to be is implemented with digital signatures.
3. Access Control – governs what resources a user may access on the system. Uses valid IDs and passwords.
4. Data Integrity – ensures info has not been tampered with. Is implemented by message digest or hashing.
5. Non-repudiation – not to deny a sale or purchase. Implemented with digital signatures.

___ Plaintext/Cleartext – message humans can read.

___ Ciphertext – unreadable to humans, uses encryption. Reverse process is called as decryption.

___ A cryptographic algorithm is called a cipher. It is a mathematical function.

Most attacks are focused on finding the “key”.

Attacks on cryptosystems occur in one for four ways:

1. Ciphertext-only – has several messages encrypted with the same key.
2. Known-plaintext – has ciphertext and plaintext to figure out the key.
3. Choose-plaintext – has ciphertext and associated plaintext for several messages.
4. Brute force – tests all possible key values until one is found.

Encryption strength is based on three factors:

1. Strength of algorithm.
2. Secrecy of key.
3. Length of key. (key lengths are determined in bits – adding a bit to the length, doubles it.)

Three kinds of cryptographic functions:

1. Symmetric – Also known as Private - involves the use of one key
 - a. Both parties must possess a single secret key. (e.g.: password on Word document).
 - b. Advantage is speed and security.
 - c. Some algorithms used:
 - i. DES (data encryption standard) – most widely used. Uses 56-bit key.

- ii. Triple DES – uses 2 keys – two 56-bit keys.
- iii. Skipjack – 80-bit key
- iv. IDEA (international data encryption algorithm) – 128-bit key
- v. Blowfish – variable key length, up to 448-bit maximum.
- 2. Asymmetric — Also known as Public - involves the use of two keys
 - a. Also called public encryption, each person has two keys – one private, one public.
 - b. Public key is published; private key is kept a secret.
 - c. Advantages is no secure channel required to transmit public key, encryption strength very secure.
 - d. Disadvantage the encryption algorithm can be slow.
 - e. RSA is the de facto standard for public key cryptosystems. The key size is normally 512 bits.
- 3. One-Way- (involves the use of no key)
Example is passwords on NT or your PIN # on bankcard.
- Message Digests:
 - i. Specific to one-way / hashing. It is to provide integrity of a message.
 - ii. The message digest is stored in the message itself.
 - iii. The message digest is unique to a message.
 - iv. A good hash function will be difficult to invert and be resistant to collisions.
 - v. Well-known hash functions:
 - 1. MD5 – results in a 128-bit message digest
 - 2. SHA (secure hash algorithm) – results in a 160-bit long message digest.

Explain in detail about Certificate Issuance

Before two parties use public-key cryptography to conduct business, each wants to be sure that the other party is authenticated. One way to be sure that the public key belongs to the right party is to receive it over a secure channel directly from the same place. However, in most circumstances this solution is not practical.

An alternative to secure transmission of the key is to use a trusted third party to authenticate that the public key belongs to Alice. Such a party is known as a *Certificate Authority (CA)*.

Because SET participants have two key pairs, they also have two certificates. Both certificates are created and signed at the same time by the Certificate Authority.

Certificate Issuance

Cardholder certificates

Cardholder certificates function as an electronic representation of the payment card. Because they are digitally signed by a financial institution, they cannot be altered by a third party and can only be generated by a financial institution. A

cardholder certificate does not contain the account number and expiration date. Instead the account information and a secret value known only to the cardholder's software are encoded using a one-way hashing algorithm. If the account number, expiration date, and the secret value are known, the link to the certificate can be proven, but the information cannot be derived by looking at the certificate. Within the SET protocol, the cardholder supplies the account information and the secret value to the payment gateway where the link is verified. A certificate is only issued to the cardholder when the cardholder's issuing financial institution approves it. By requesting a certificate, a cardholder has indicated the intent to perform commerce via electronic means. This certificate is transmitted to merchants with purchase requests and encrypted payment instructions. Upon receipt of the cardholder's certificate, a merchant can be assured, at a minimum, that the account number has been validated by the card-issuing financial institution or its agent. In this specification, cardholder certificates are optional at the payment card brand's discretion.

Merchant certificates

Merchant certificates function as an electronic substitute for the payment brand decal that appears in the store window—the decal itself is a representation that the merchant has a relationship with a financial institution allowing it to accept the payment card brand. Because they are digitally signed by the merchant's financial institution, merchant certificates cannot be altered by a third party and can only be generated by a financial institution. These certificates are approved by the acquiring financial institution and provide assurance that the merchant holds a valid agreement with an Acquirer. A merchant must have at least one pair of certificates to participate in the SET environment, but there may be multiple certificate pairs per merchant. A merchant will have a pair of certificates for each payment card brand that it accepts.

Payment Gateway Certificates

Payment gateway certificates are obtained by Acquirers or their processors for the systems that process authorization and capture messages. The gateway's encryption key, which the cardholder gets from this certificate, is used to protect the cardholder's account information. Payment gateway certificates are issued to the Acquirer by the payment brand.

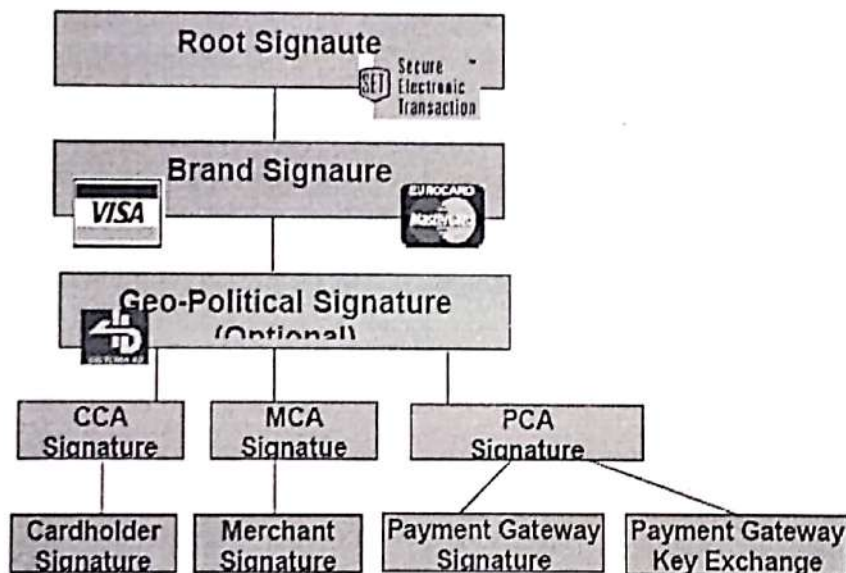
Acquirer Certificates

An Acquirer must have certificates in order to operate a Certificate Authority that can accept and process certificate requests directly from merchants over public and private networks. Those Acquirers that choose to have the payment

card brand process certificate requests on their behalf will not require certificates because they are not processing SET messages. Acquirers receive their certificates from the payment card brand.

Issuer Certificates

An Issuer must have certificates in order to operate a Certificate Authority that can accept and process certificate requests directly from cardholders over public and private networks. Those Issuers that choose to have the payment card brand process certificate requests on their behalf will not require certificates because they are not processing SET messages. Issuers receive their certificates from the payment card brand.



Summarize the most common SET transaction flows.

(15) May '11

4. Payment Processing

SET as a variety of transaction protocols that utilize the cryptographic concepts to securely conduct electronic commerce.

The following transactions are specified:

- **Cardholder registration**
- Card holders must register with a Certificate Authority (CA) before they can send SET messages to merchants.

- In order to send SET messages to CA, the card holder must have a copy of the CA public key exchange key, which is provided in the CA key-exchange certificate
 - Cardholder initiates registration:
 - Certificate Authority sends response
 - Cardholder receives response and requests registration form
 - Certificate authority processes request and sends registration form
 - Cardholder receives registration form and requests certificate
 - Certificate authority processes request and creates certificate
 - Cardholder receives certificate:

When the card holder software receives the response from the CA, it verifies the certificate by traversing the trust chain to the root key.

It stores the certificate on the cardholder's computer for use in future electronic commerce transactions.

- **Merchant registration**

- Merchant requests registration form
- Certificate authority processes request and sends registration form
- Merchant receives registration form and requests certificates
- Certificate authority processes request and creates certificates
- Merchant receives certificates

- **Purchase request**

Cardholder initiates request
Merchant sends certificates
Cardholder receives response and sends request
Merchant processes request message
Cardholder receives purchase response

- **Payment authorization**

Merchant request authorization

- The merchant software generates and digitally signs an authorization request, which includes the amount to be authorized, the transaction identifier from the OI and other information about the transaction.
- The request is then encrypted using a new randomly generated symmetric key, which in turn is encrypted using the public key-exchange key of the payment gateway
- The authorization request and the cardholder payment instructions are then transmitted to the payment gateway.

- Payment gateway processes authorization request
- Merchant process response
- **Payment capture**
 - Merchant requests payment
 - Payment gateway processes capture request
 - Merchant receives response

Other transactions:

- **Certificate inquiry**
 - This message is used to determine the status of the certificate request and to receive the certificate if the request has been approved
- **Purchase inquiry**
 - This message indicate the status of authorization, capture and credit processing
- **Purchase notification**
- **Sale transaction**
- **Authorization reversal**
 - This will allow a merchant to correct previous authorization requests.
- **Capture reversal**
 - It allows a merchant to correct errors in capture requests such as transaction amounts that were entered incorrectly by a clerk.
- **Credit**
 - This message allows a merchant to issue a credit to a cardholder's account such as when goods are returned or were damaged during shipping.
- **Credit reversal**
 - It allows a merchant to correct errors in credit messages.
- **Payment gateway certificate request**
 - The payment gateway certificate request message allows a merchant to query the payment gateway and receive a copy of the gateway's current key-exchange and signature certificates

- Batch administration message allows a merchant to communicate information to the payment gateway regarding merchant batches.

Explain cardholder registration process in a card based system. (6) May '11

Cardholder registration

Card holders must register with a Certificate Authority (CA) before they can send SET messages to merchants.

In order to send SET messages to CA, the card holder must have a copy of the CA public key exchange key, which is provided in the CA key-exchange certificate

(I) Cardholder initiates registration :

(i) When CA receives the request, it transmits its certificates to the cardholder. The CA key-encryption certificate provides the cardholder software with the information necessary to protect the payment card account number in the registration form request.

(ii) Certificate Authority sends response:

The card holder software verifies the CA certificate by traversing the trust chain to the root key.

The software must hold the CA certificates to use later during the registration process.

Once the software has a copy of the CA key exchange certificate, the cardholder can request a registration form.

(iii) Cardholder receives response and requests registration form:

The CA identifies the cardholder's financial institution *(using the first six to eleven digits of the account number) and selects the appropriate registration form.

It digitally sign and then returns this registration form to the card holder.

(iv) Certificate authority processes request and sends registration form:

The card holder software verifies the CA certificate by traversing the trust chain to the root key.

The cardholder needs a signature public/private key pair for use with SET.

To register an account, the cardholder fills out the registration form that was returned by the CA with information such as the cardholder's name, expiration date, account billing address, and any additional information the issuing financial institution deems necessary to identify the certificate requester as the valid card holder

The cardholder software generates this key pair if it does not already exist.

(v) Cardholder receives registration form and requests certificate:

The cardholder software takes this registration information and combines it with the public key in a registration message,

The software generates two random symmetric encryption keys.

The software generates two random symmetric encryption keys.

The software places one random key inside the message; the CA will use this key to encrypt the response.

It uses the other random key to encrypt the registration message.

This random key is then encrypted along with the account number, expiration date, and the random number into the digital envelope using the CA public key-exchange key. Finally, the software transmits all of these components to the CA.

(vi) Certificate authority processes request and creates certificate:

A response message containing the random number generated by the CA and other information (such as the brand logo) is then generated and encrypted using the symmetric key sent by the cardholder software in the registration message.

The response is then transmitted to the cardholder.

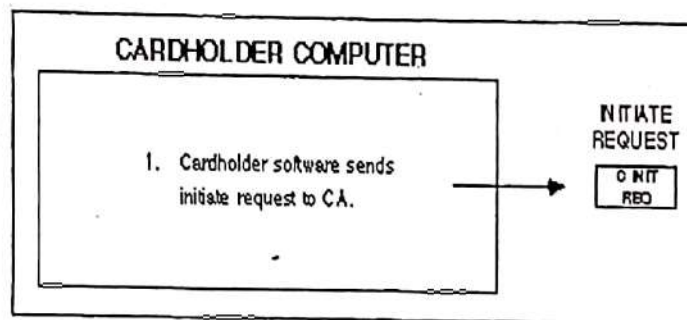
(vii) Cardholder receives certificate:

When the cardholder software receives the response from the CA, it verifies the certificate by traversing the trust chain to the root key.

It stores the certificate on the cardholder's computer for use in future electronic commerce transactions.

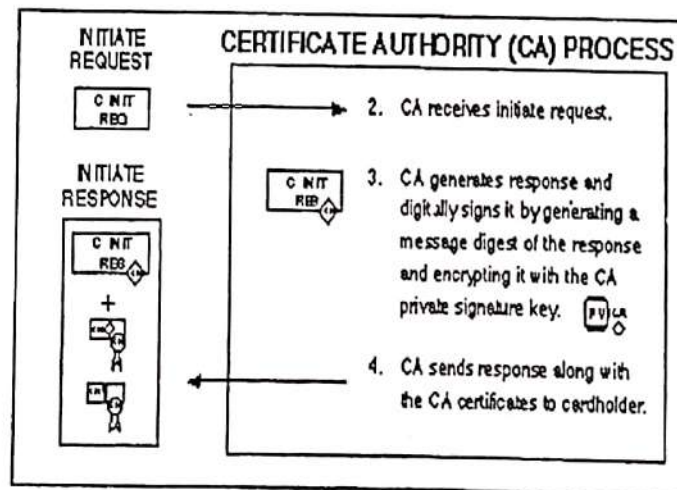
Certificate authority processes request and creates certificate

Cardholder initiates registration



When the CA receives the request, it transmits its certificates to the cardholder. The CA key-encryption certificate provides the cardholder software with the information necessary to protect the payment card account number in the registration form request.

Certificate Authority sends response

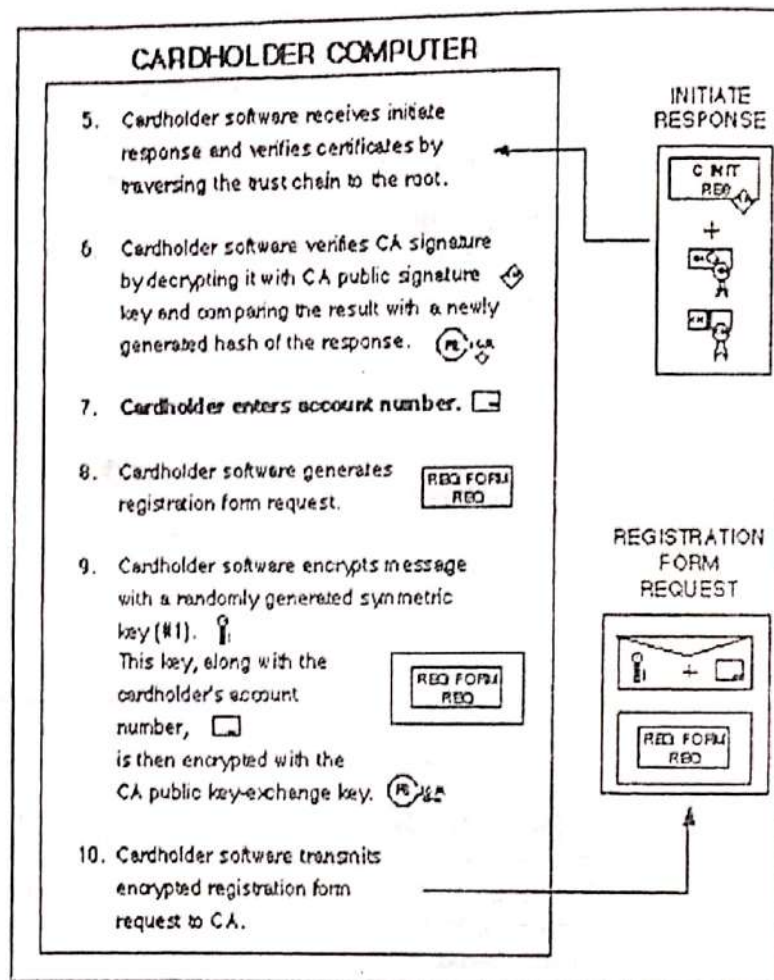


The cardholder software verifies the CA certificate by traversing the trust chain to the root key. The software must hold the CA certificates to use later during the registration process. Once the software has a copy of the CA key-exchange certificate, the cardholder can request a registration form.

The cardholder software creates a registration form request message. Next the software generates a random symmetric encryption key.

It uses this random key to encrypt the registration form request message. The random key is then encrypted along with the account number into the digital envelope using the CA public key-exchange key. Finally, the software transmits all of these components to the CA.

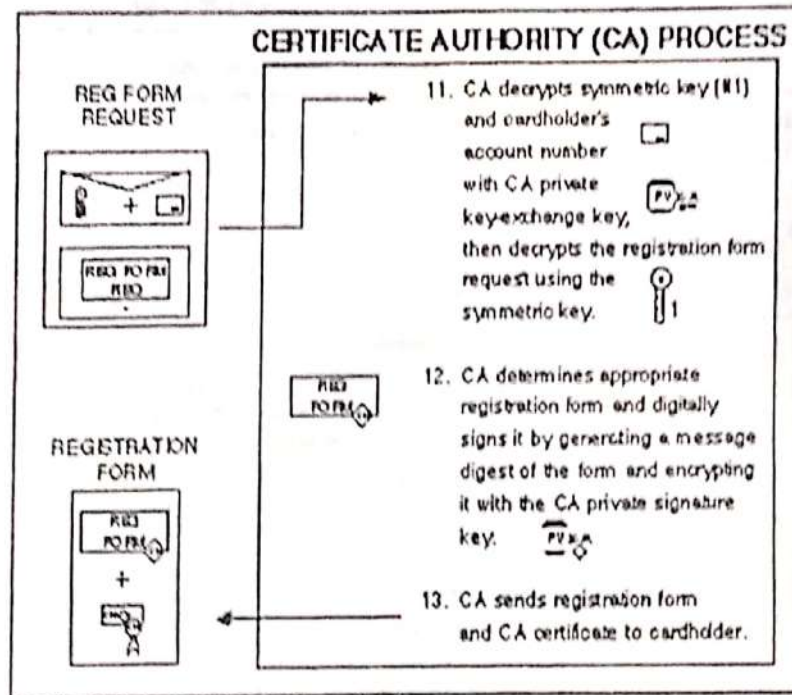
Cardholder receives response and requests registration form



The CA identifies the cardholder's financial institution (using the first six to eleven digits of the account number) and selects the appropriate registration form. It digitally signs and then returns this registration form to the cardholder.

In some cases, the CA may not have a copy of the registration form but can inform the cardholder software where the form can be obtained. For example, the cardholder's issuing financial institution may operate its own CA. In this event, the CA returns a referral response instead of the registration form. (This referral response is not shown in the diagram below.)

Certificate Authority processes request and sends registration form

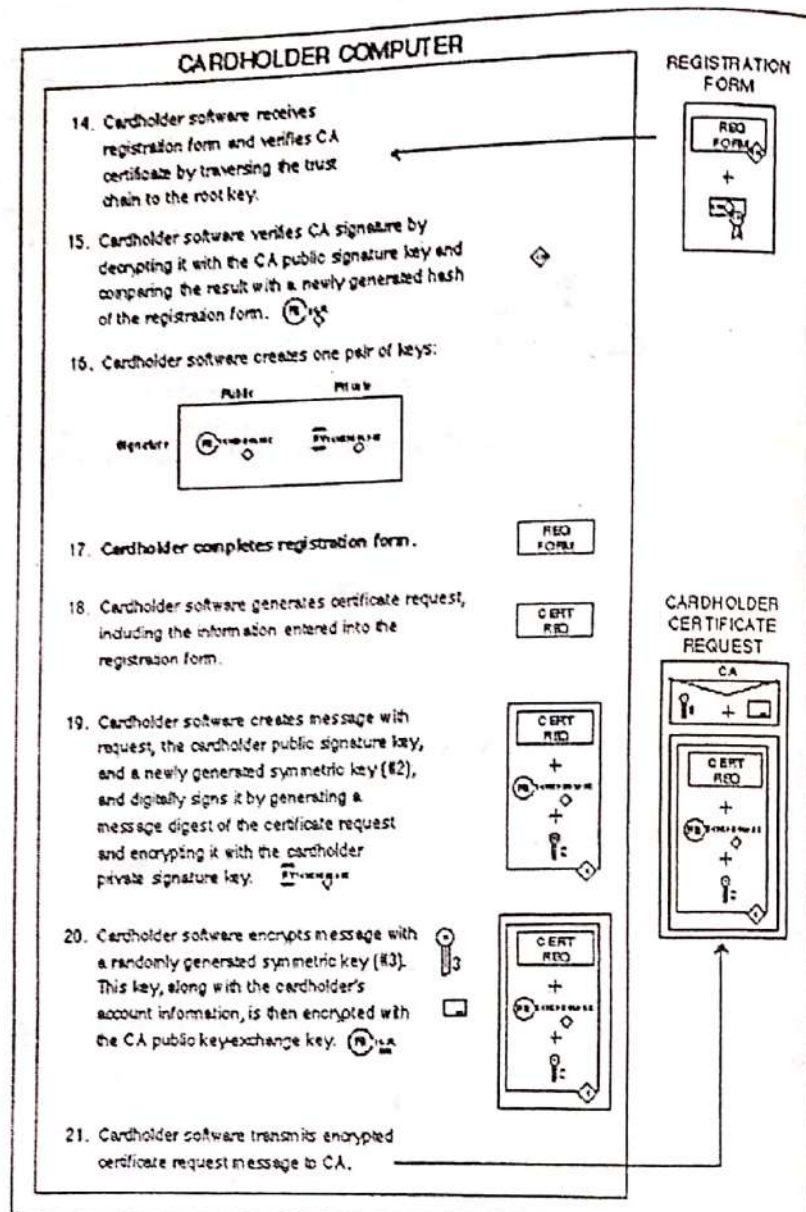


The cardholder software verifies the CA certificate by traversing the trust chain to the root key.

The cardholder needs a signature public/private key pair for use with SET. The cardholder software generates this key pair if it does not already exist.

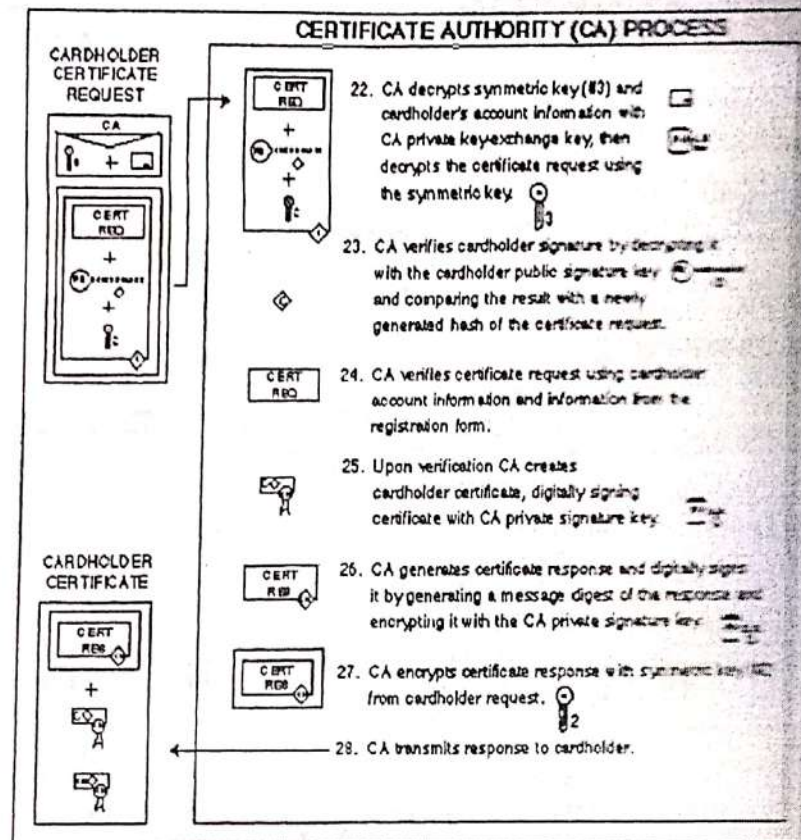
To register an account, the cardholder fills out the registration form that was returned by the CA with information such as the cardholder's name, expiration date, account billing address, and any additional information the issuing financial institution deems necessary to identify the certificate requester as the valid cardholder.

Cardholder receives registration form and requests certificate



When the CA receives the cardholder's request, it decrypts the digital envelope to obtain the symmetric encryption key, the account infor-

Certificate Authority processes request and creates certificate

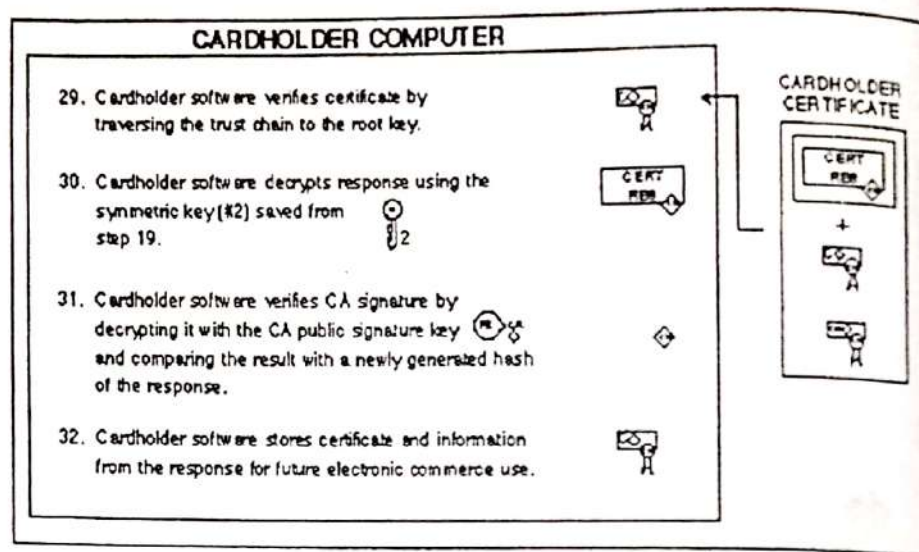


When the cardholder software receives the response from the CA, it verifies the certificate by traversing the trust chain to the root key. It stores the certificate on the cardholder's computer for use in future electronic commerce transactions.

Next, the cardholder software decrypts the registration response using the symmetric encryption key that it sent to the CA in the registration message. It combines the random number returned by the CA with the value that it sent in the registration message to determine the secret value. It then stores the secret value to use with the certificate.

Cardholder software vendors will ensure that the certificate and related information is stored in a way to prevent unauthorized access.

Cardholder receives certificate



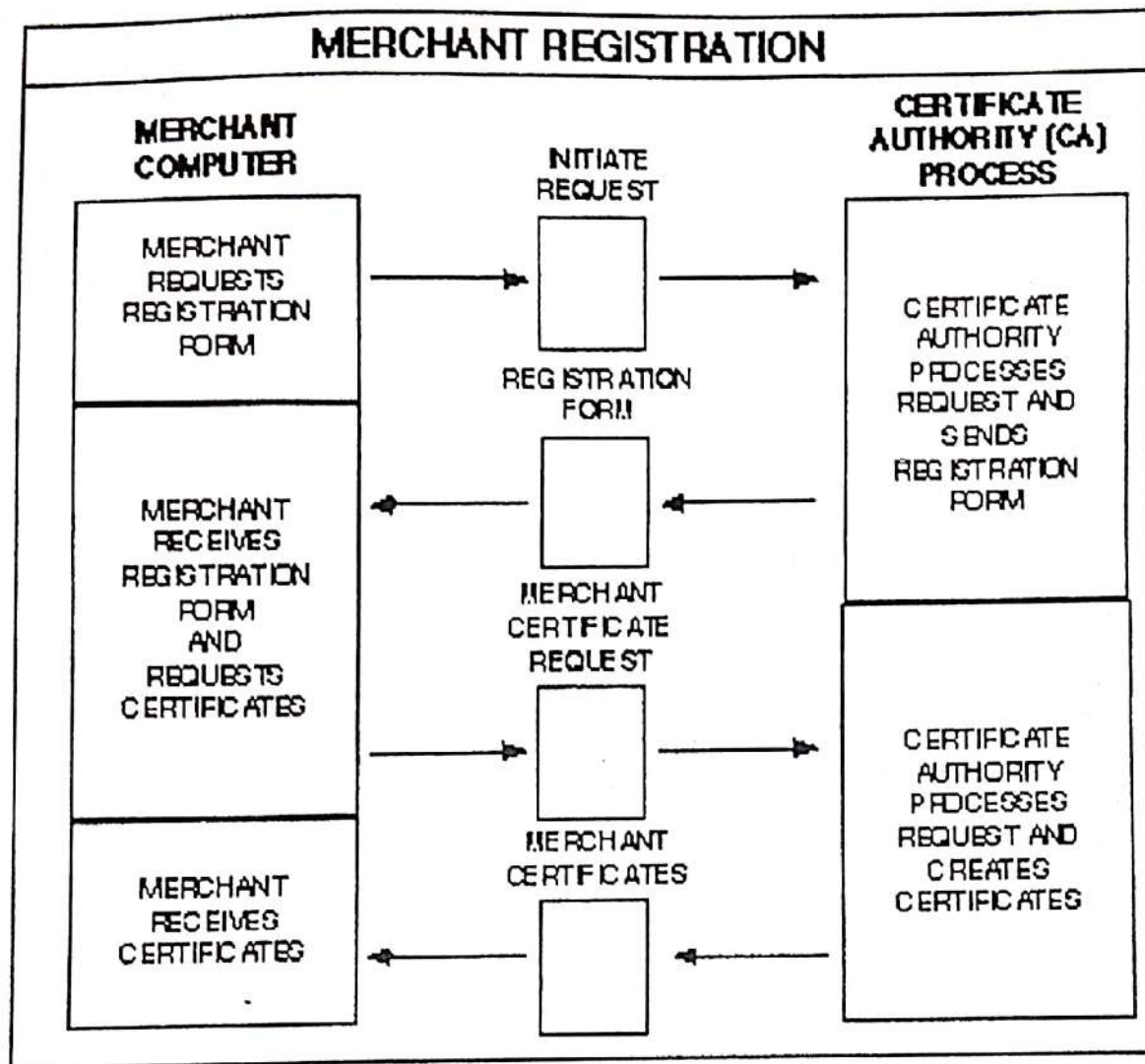
4.3 Merchant Registration

The figure shown below provides a high level overview of the merchant registration process. This scenario is divided into its five fundamental steps in the following detailed sections. The icon to the left corresponds to the diagram below and serves as a map to this scenario; it is repeated in the explanations of the more detailed diagrams with a shaded region that indicates which step is being described.

Discuss merchant registration process in a card based system.(8) May'09

Merchant registration Steps:

- Merchant requests registration form
- Certificate authority processes request and sends registration form
- Merchant receives registration form and requests certificates
- Certificate atuhority processes request and creates certificates
- Merchant receives certificates

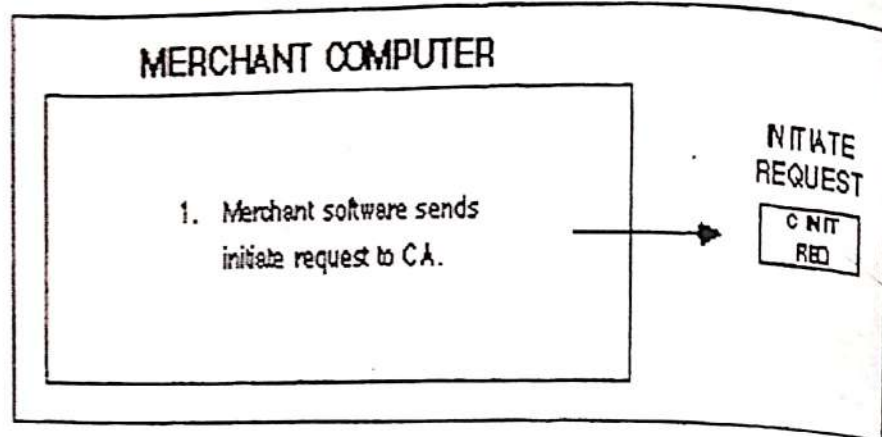


Merchants must register with a Certificate Authority (CA) before they can receive SET payment instructions from cardholders or process SET transactions through a payment gateway. In order to send SET messages to the CA, the merchant must have a copy of the CA public key-exchange key, which is provided in the CA key-exchange certificate.

The merchant also needs a copy of the registration form from the merchant's financial institution. The merchant software must identify the Acquirer to the CA.

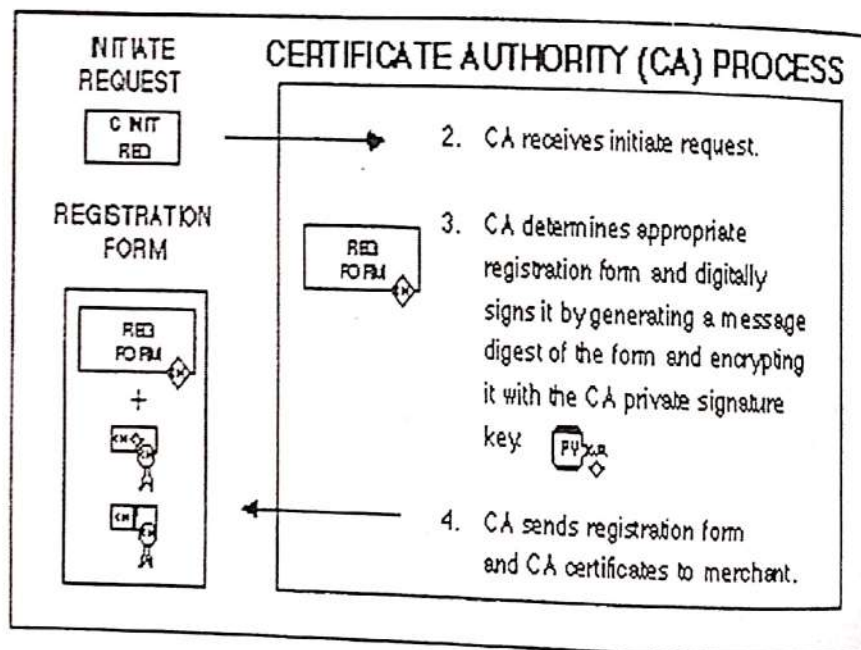
The registration process is started when the merchant software requests a copy of the CA's key-exchange certificate and the appropriate registration form.

Merchant requests registration form



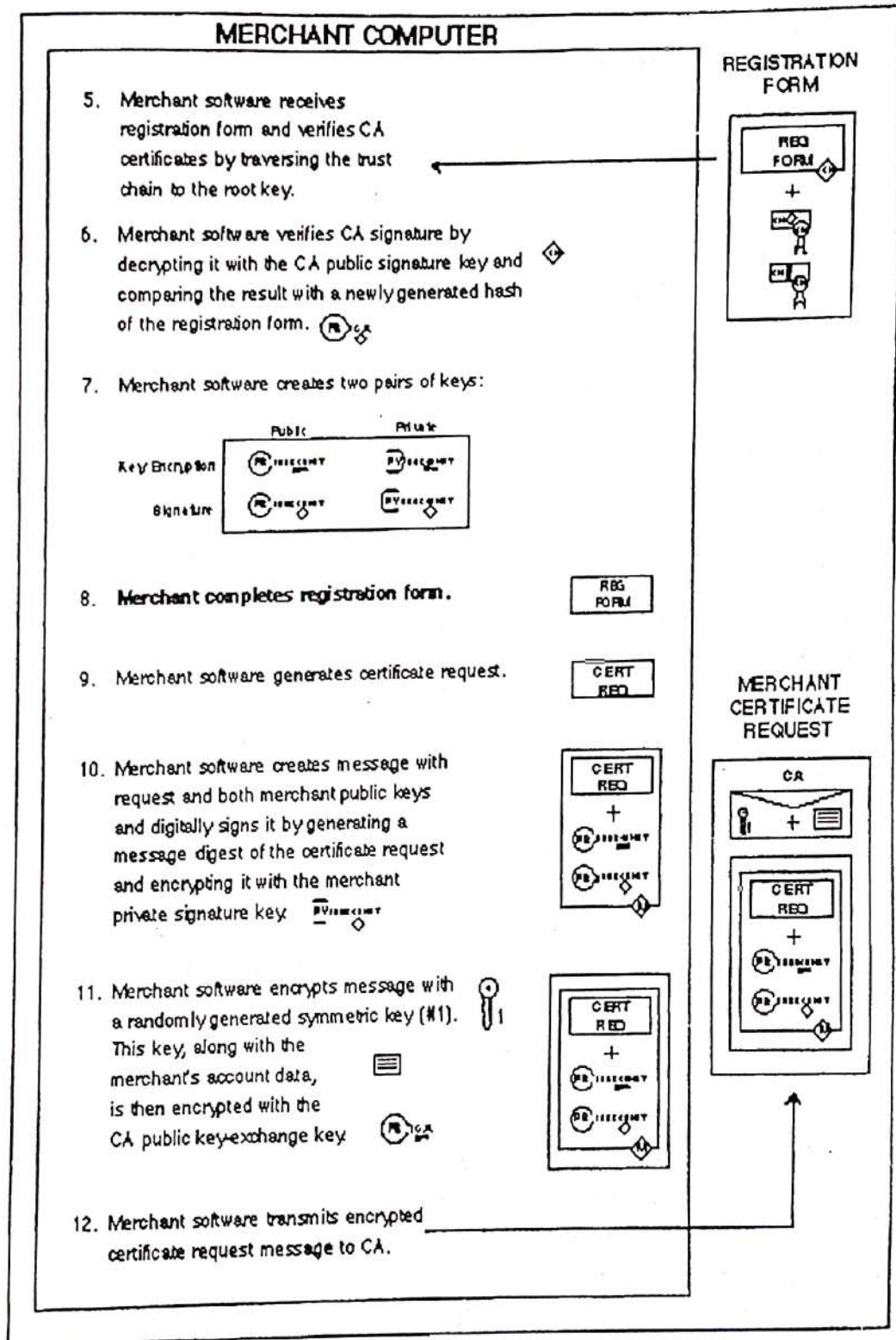
The CA identifies the merchant's financial institution and selects the appropriate registration form. It returns this registration form along with a copy of its own key-exchange certificate to the merchant.

Certificate Authority processes request and sends registration form

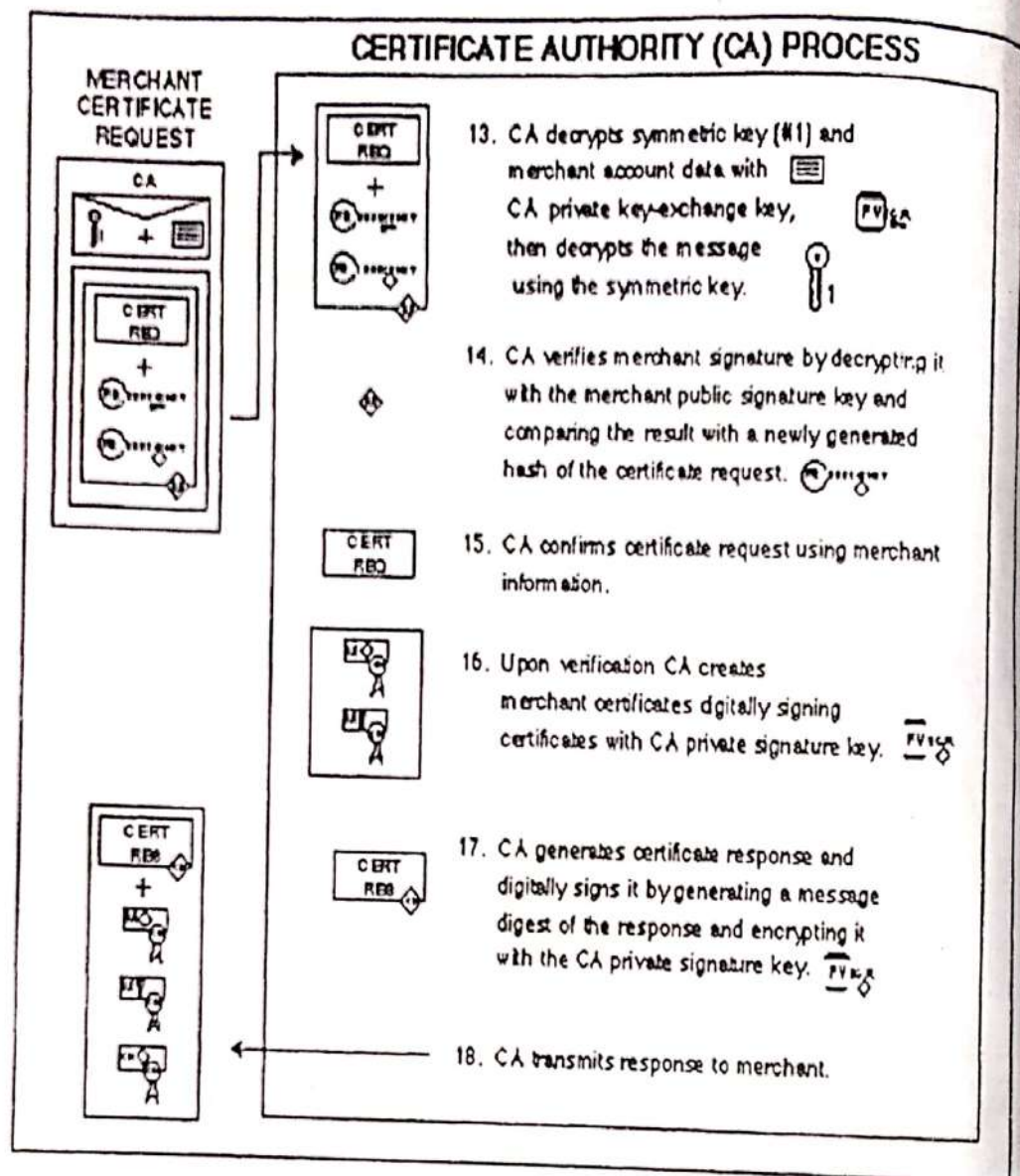


The merchant software verifies the CA certificate by traversing the trust chain to the root key. The merchant software must hold the CA certificate to use later during the registration process. Once the software has a copy of the CA key-exchange certificate, the merchant can register to accept SET payment instructions and process SET transactions. The merchant must have a relationship with an Acquirer that

Merchant receives registration form and requests certificates

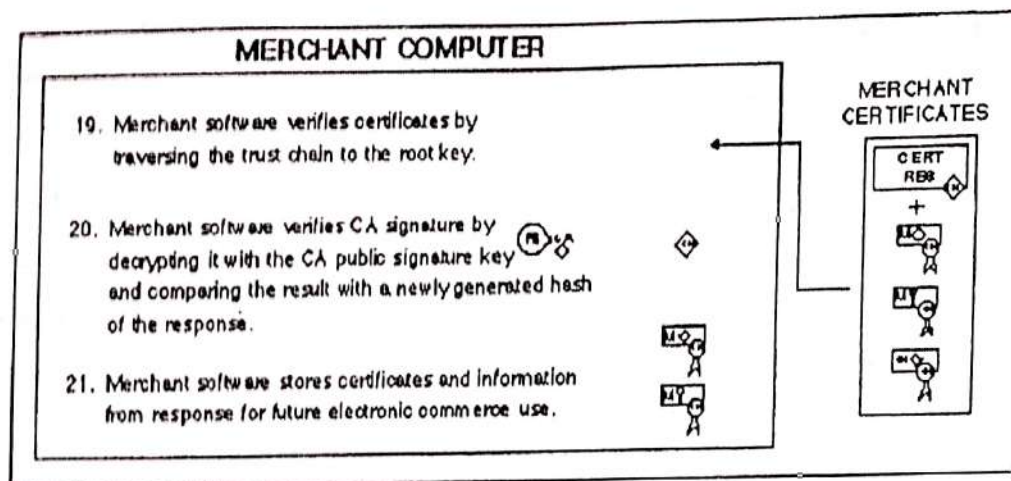


Certificate Authority processes request and creates certificates



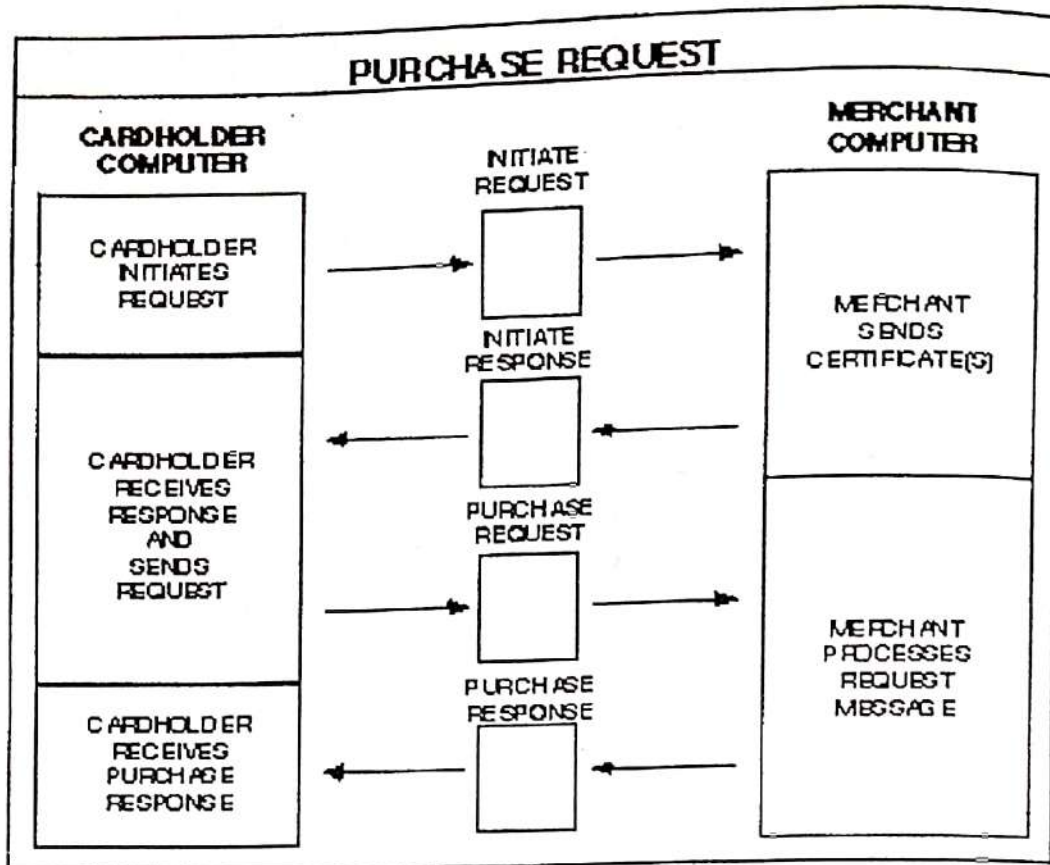
When the merchant software receives the response from the CA, it decrypts the digital envelope to obtain the symmetric encryption key. It uses the symmetric key to decrypt the registration response containing the merchant certificates.

After the merchant software verifies the certificates by traversing the trust chain to the root key, it stores the certificates on the merchant's computer for use in future electronic commerce transactions.

Merchant receives certificates**4.4 Purchase Request**

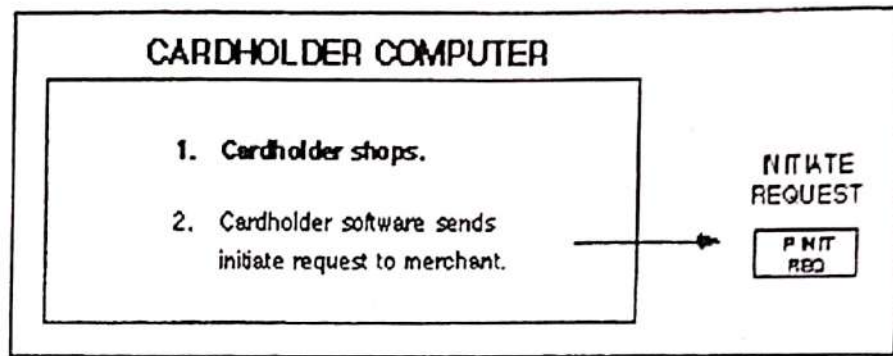
The figure shown below provides a high level overview of the purchase request portion of a cardholder's order process. This scenario is divided into its five fundamental steps in the following detailed sections. The icon to the left corresponds to the diagram below and serves as a map to this scenario; it is repeated in the explanations of the more detailed diagrams with a shaded region that indicates which step is being described.

Explain Purchase request



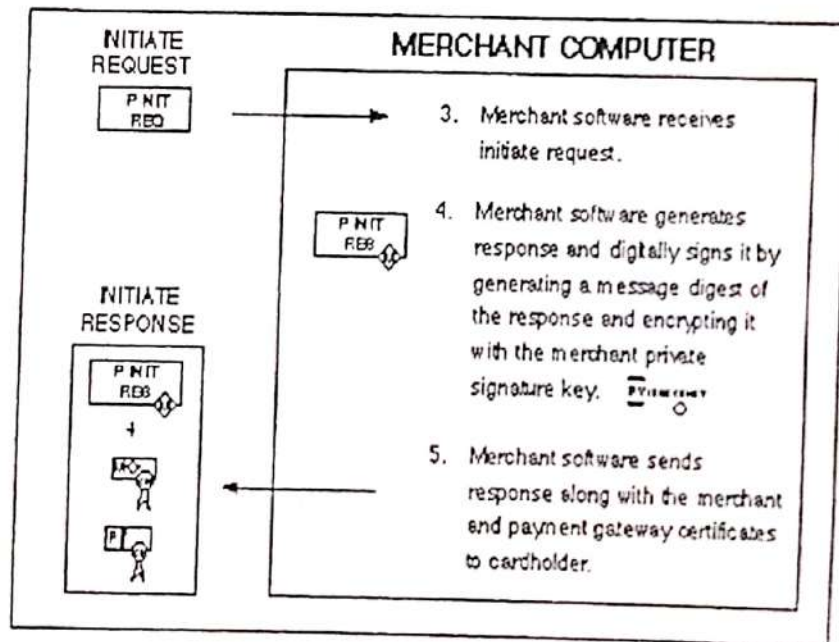
The SET protocol is invoked after the cardholder has completed browsing, selection and ordering. Before this flow begins, the cardholder will have been presented with a completed order form and approved its contents and terms such as the number of installment payments if the merchant is billing for the transaction in installments. In addition, the cardholder will have selected a payment card as the means of payment.

In order to send SET messages to a merchant, the cardholder must have a copy of the merchant public key-exchange key as well as the Payment Gateway's key-exchange keys. The SET order process is started when the cardholder software requests a copy of the merchant's and gateway's certificates. The message from the cardholder indicates which payment card brand will be used for the transaction.



When the merchant receives the request, it assigns a unique transaction identifier to the message. It then transmits the merchant and gateway certificates that correspond to the payment card brand indicated by the cardholder along with the transaction identifier to the cardholder.

Merchant sends certificate(s)



The cardholder software verifies the merchant and gateway certificates by traversing the trust chain to the root key. The software must hold these certificates to use later during the ordering process.

The cardholder software creates the Order Information (OI) and Payment Instructions (PI). The software places the transaction identifier assigned by the merchant in the OI and the PI; this identifier will be used by the Payment Gateway to link the OI and the PI together when the merchant requests authorization.

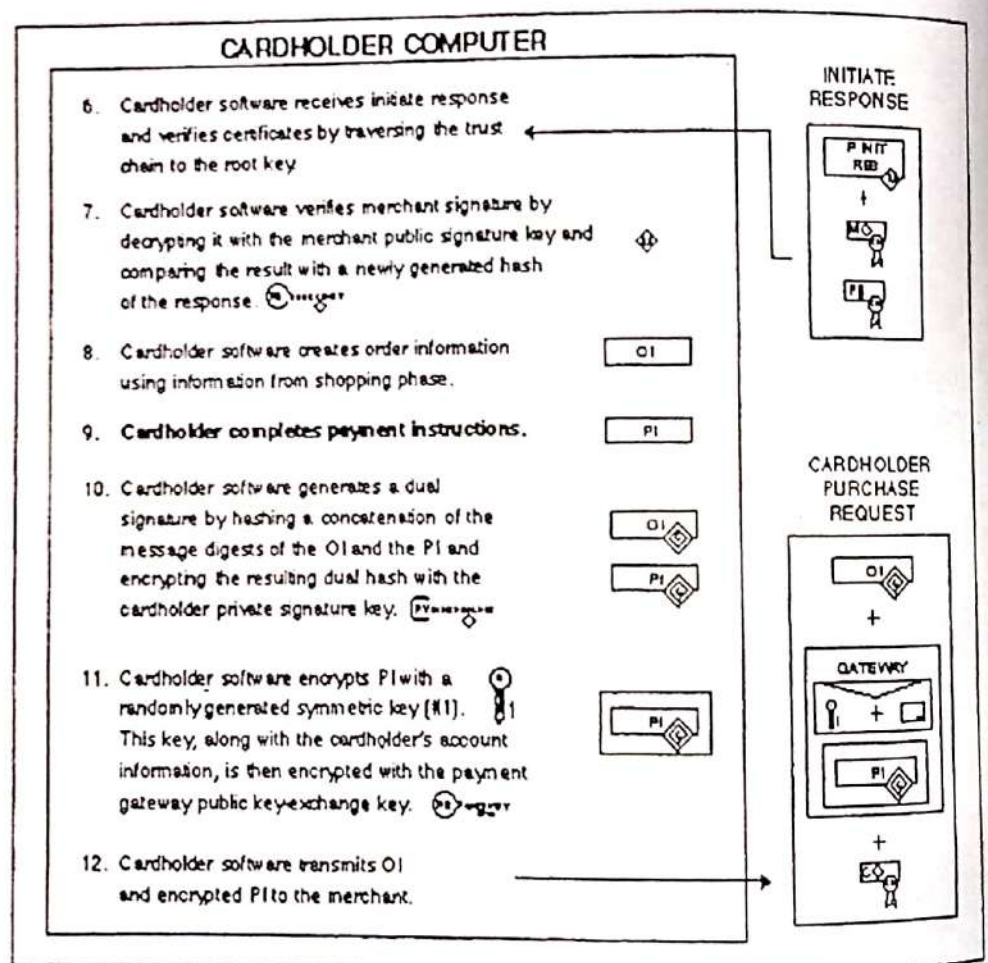
Note: The OI does not contain the order data such as the description of goods (the items and quantities) or the terms of the order (such as number of installment payments). This information is exchanged between the cardholder and merchant software during the shopping phase before the first SET message.

The cardholder software generates a dual signature for the OI and the PI by computing the message digests of both, concatenating the two digests, computing the message digest of the result and encrypting that using the cardholder private signature key. The message digests of the OI and the PI are sent along with the dual signature.

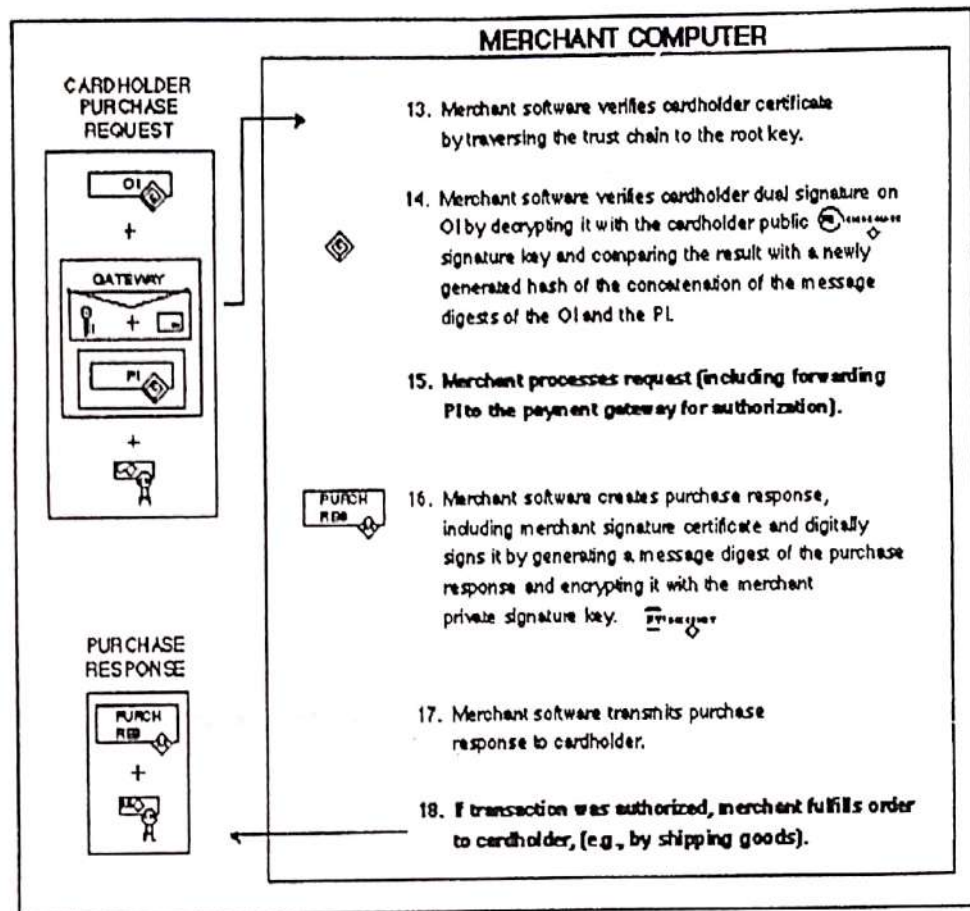
Next the software generates a random symmetric encryption key and uses it to encrypt the dual signed PI. The software then encrypts the cardholder account number as well as the random symmetric key used to encrypt the PI into a digital envelope using the Payment Gateway's key-exchange key.

Finally, the software transmits a message consisting of the OI and the PI to the merchant.

Cardholder receives response
and sends request



Merchant processes request message

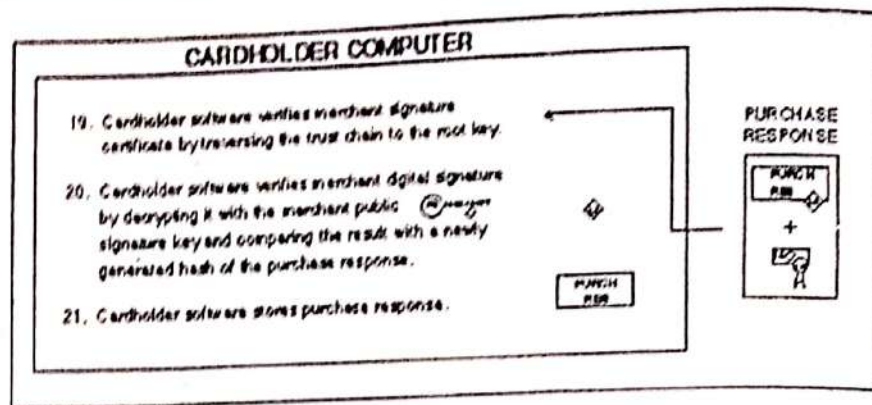


When the cardholder software receives the purchase response message from the merchant, it verifies the merchant signature certificate by traversing the trust chain to the root key. It uses the merchant public signature key to check the merchant's digital signature. Finally, it takes some action based on the contents of the response message, such as displaying a message to the cardholder or updating a database with the status of the order.

The cardholder can determine the status of the order (such as whether it has been authorized or submitted for payment) by sending an order inquiry message. This message is described in Book 2: Programmer's Guide.

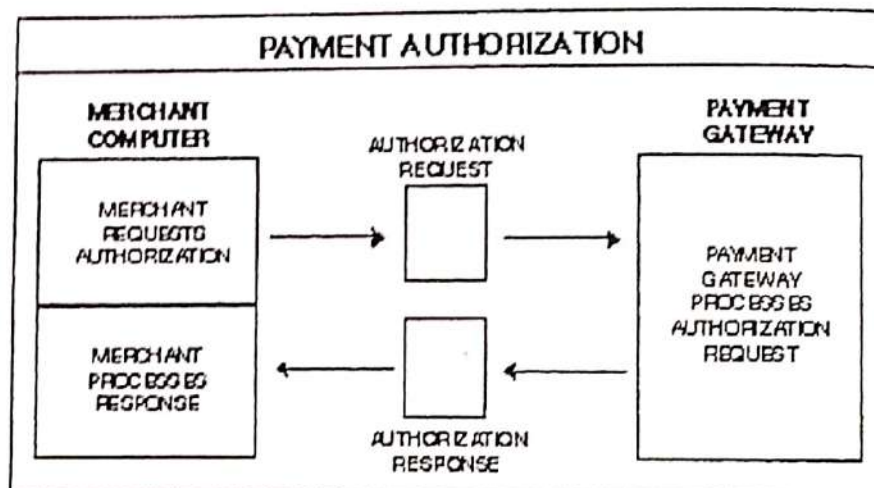
Explain Payment authorization

Cardholder receives purchase response



4.5 Payment Authorization

The figure shown below provides a high level overview of a merchant's payment authorization process. This scenario is divided into its three fundamental steps in the following detailed sections. The icon to the left corresponds to the diagram below and serves as a map to this scenario; it is repeated in the explanations of the more detailed diagrams with a shaded region that indicates which step is being described.

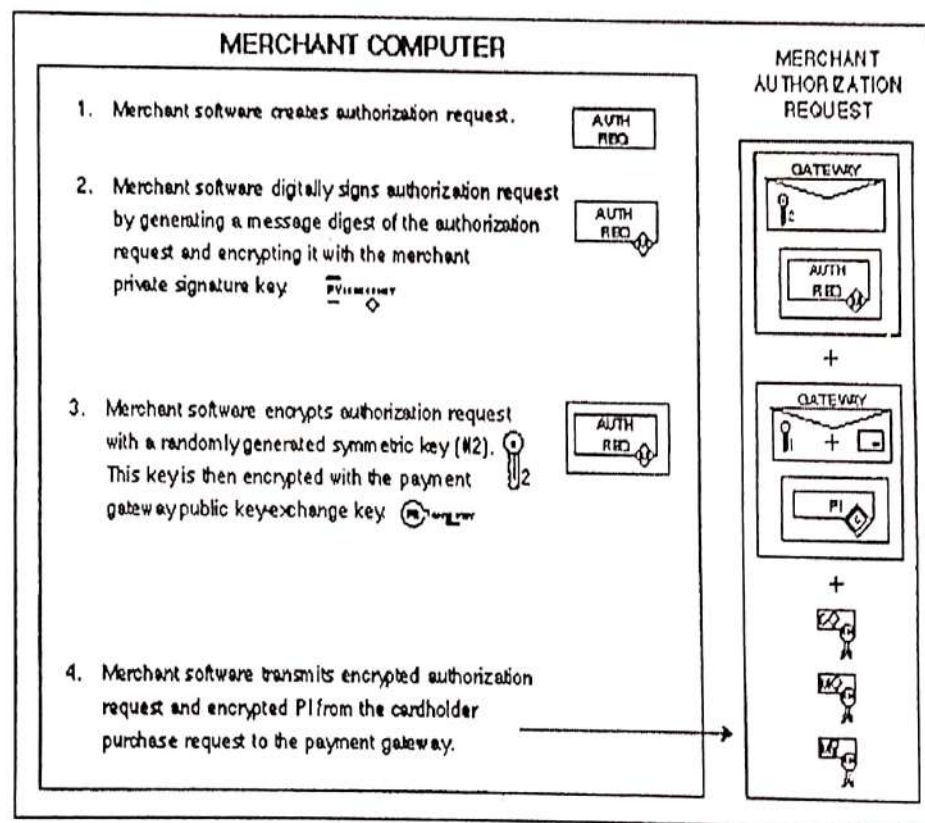


During the processing of an order from a cardholder (see Section 4.4), the merchant will authorize the transaction. The merchant software generates and digitally signs an authorization request, which

includes the amount to be authorized, the transaction identifier from the OI and other information about the transaction. The request is then encrypted using a new randomly generated symmetric key, which in turn is encrypted using the public key-exchange key of the Payment Gateway. (This is the same key the cardholder used to encrypt the digital envelope of the payment instructions.) The authorization request and the cardholder payment instructions are then transmitted to the Payment Gateway.

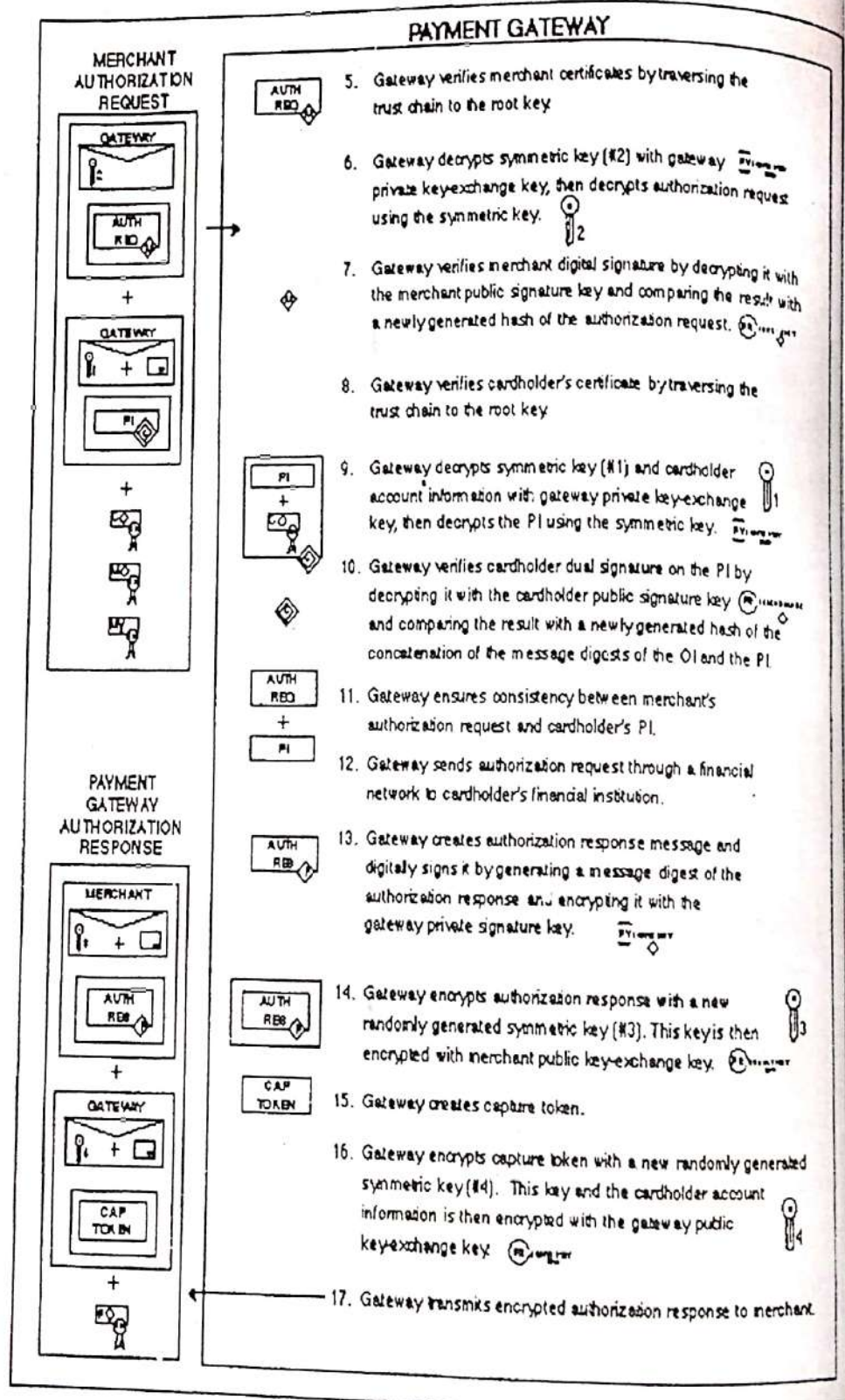
Note: The SET protocol also includes a sales transaction that allows a merchant to authorize a transaction and request payment in a single message. While the sales message includes an additional block of data on the request from the merchant, it otherwise parallels the message flow being described in this section. Details about the processing of a sales transaction are provided in Book 2: Programmer's Guide.

Merchant requests authorization



When the Payment Gateway receives the authorization request, it decrypts the digital envelope of the authorization request to obtain the symmetric encryption key. It uses the symmetric key to decrypt the request. It then verifies the merchant signature certificate by travers-

Payment Gateway processes authorization request

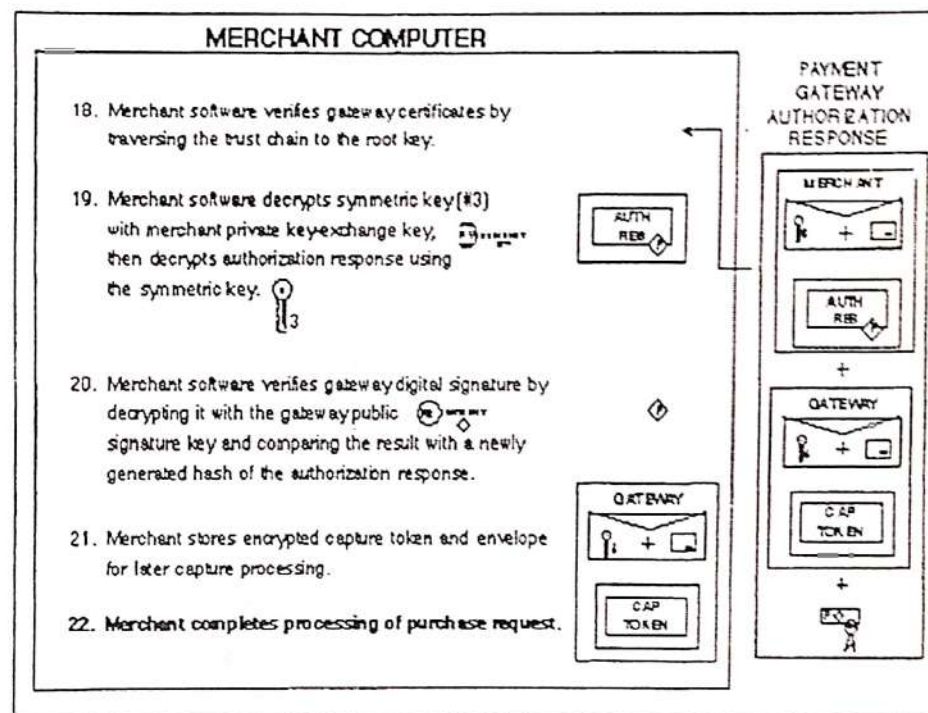


When the merchant software receives the authorization response message from the Payment Gateway, it decrypts the digital envelope to obtain the symmetric encryption key. It uses the symmetric key to

decrypt the response message. It then verifies the Payment Gateway signature certificate by traversing the trust chain to the root key. It uses the Payment Gateway public signature key to check the Payment Gateway digital signature.

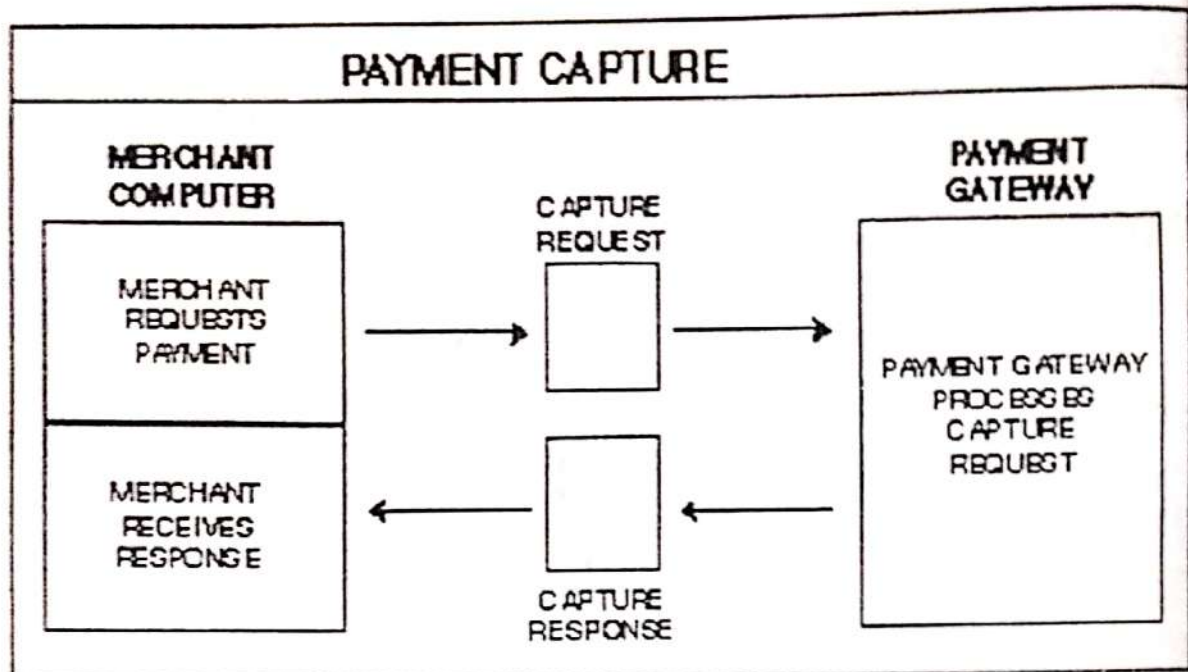
The merchant software will store the authorization response and the capture token to be used when requesting payment through a capture request (see Section 4.6). The merchant then completes processing of the cardholder's order (see Section 4.4) by shipping the goods or performing the services indicated in the order.

Merchant processes response



4.6 Payment Capture

The figure shown below provides a high level overview of a merchant's payment capture process. This scenario is divided into its three fundamental steps in the following detailed sections. The icon to the left corresponds to the diagram below and serves as a map to this scenario; it is repeated in the explanations of the more detailed diagrams with a shaded region that indicates which step is being described.

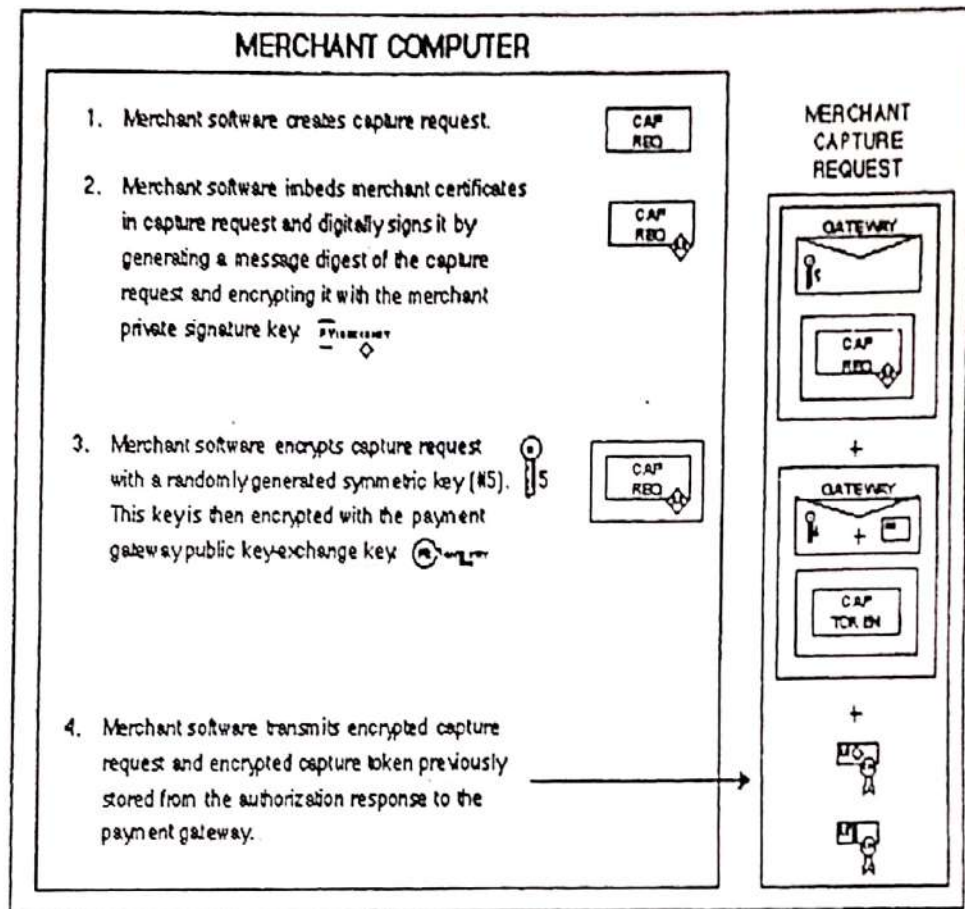


After completing the processing of an order from a cardholder (see Section 4.4), the merchant will request payment. There will often be a significant time lapse between the message requesting authorization and the message requesting payment.

The merchant software generates and digitally signs a capture request, which includes the final amount of the transaction, the transaction identifier from the OI and other information about the transaction. The request is then encrypted using a new randomly generated symmetric key, which in turn is encrypted using the public key-exchange key of the Payment Gateway. The capture request and optionally the capture token if one was included in the authorization response (see Section 4.5) are then transmitted to the Payment Gateway.

Note: While the flow described here contains only a single capture request, the merchant software is permitted to batch multiple requests into a single message.

Merchant requests payment

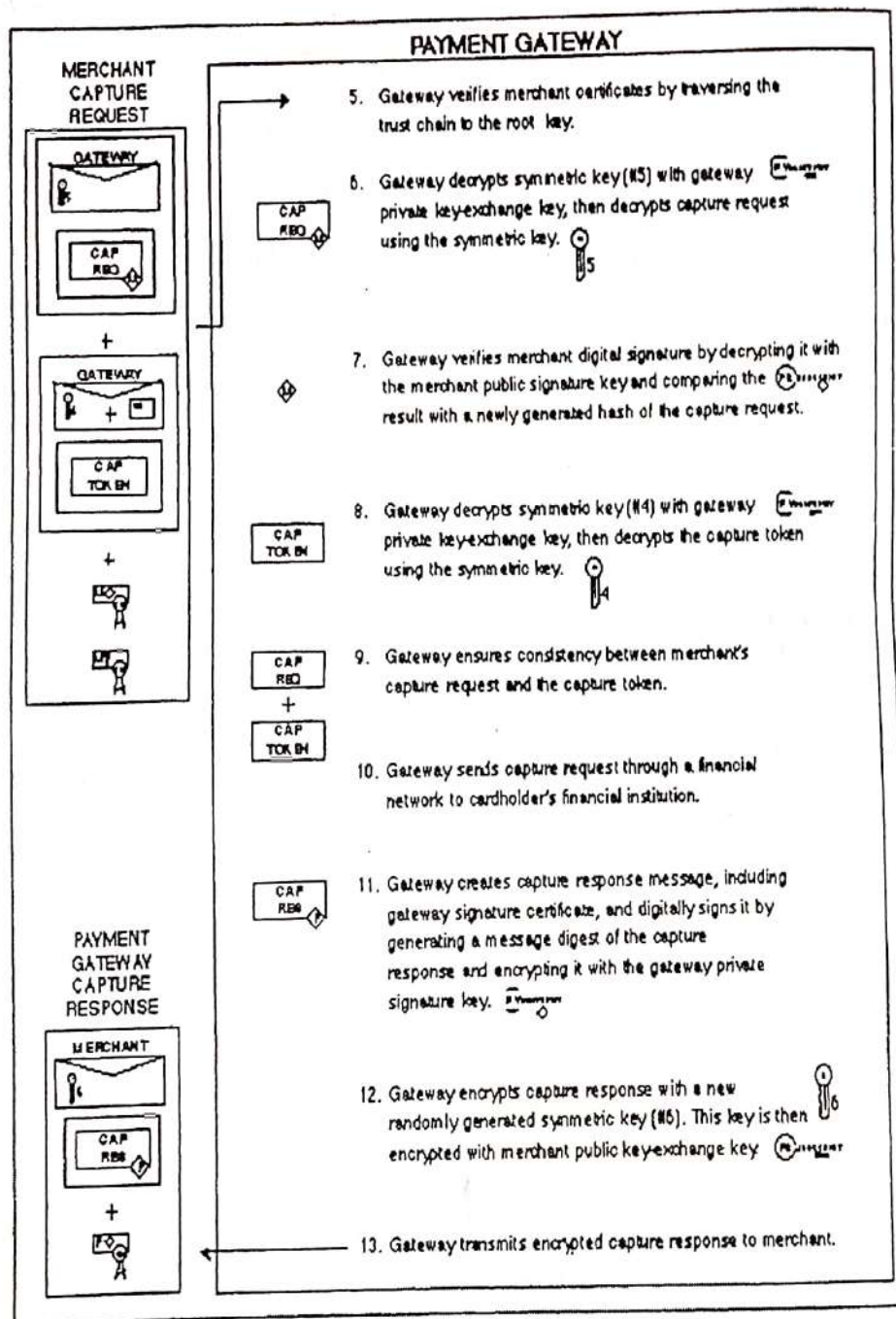


When the Payment Gateway receives the capture request, it decrypts the digital envelope of the capture request to obtain the symmetric encryption key. It uses the symmetric key to decrypt the request. It then uses the merchant public signature key to ensure the request was signed using the merchant private signature key.

The Payment Gateway decrypts the capture token (if present) and then uses the information from the capture request and the capture token to format a clearing request, which it sends to the Issuer via a payment card payment system.

The Payment Gateway then generates and digitally signs a capture response message, which includes a copy of the Payment Gateway signature certificate. The response is then encrypted using a new randomly generated symmetric key, which in turn is encrypted using the merchant public key-exchange key. The response is then transmitted to the merchant.

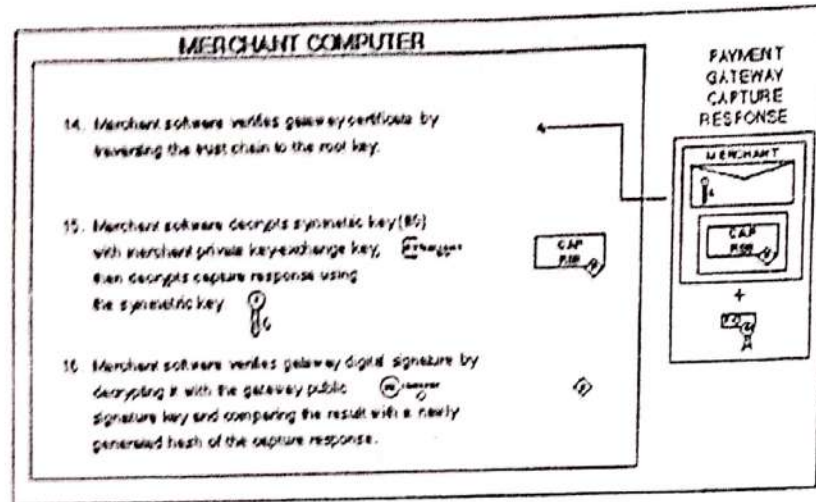
Payment Gateway processes capture request



When the merchant software receives the capture response message from the Payment Gateway, it decrypts the digital envelope to obtain the symmetric encryption key. It uses the symmetric key to decrypt the response message. It then verifies the Payment Gateway signature certificate by traversing the trust chain to the root key. It uses the Payment Gateway public signature key to check the Payment Gateway digital signature.

The merchant software will store the capture response to be used for reconciliation with payment received from the Acquirer.

Merchant receives response



How does a Email work ?

(7) (May '10)

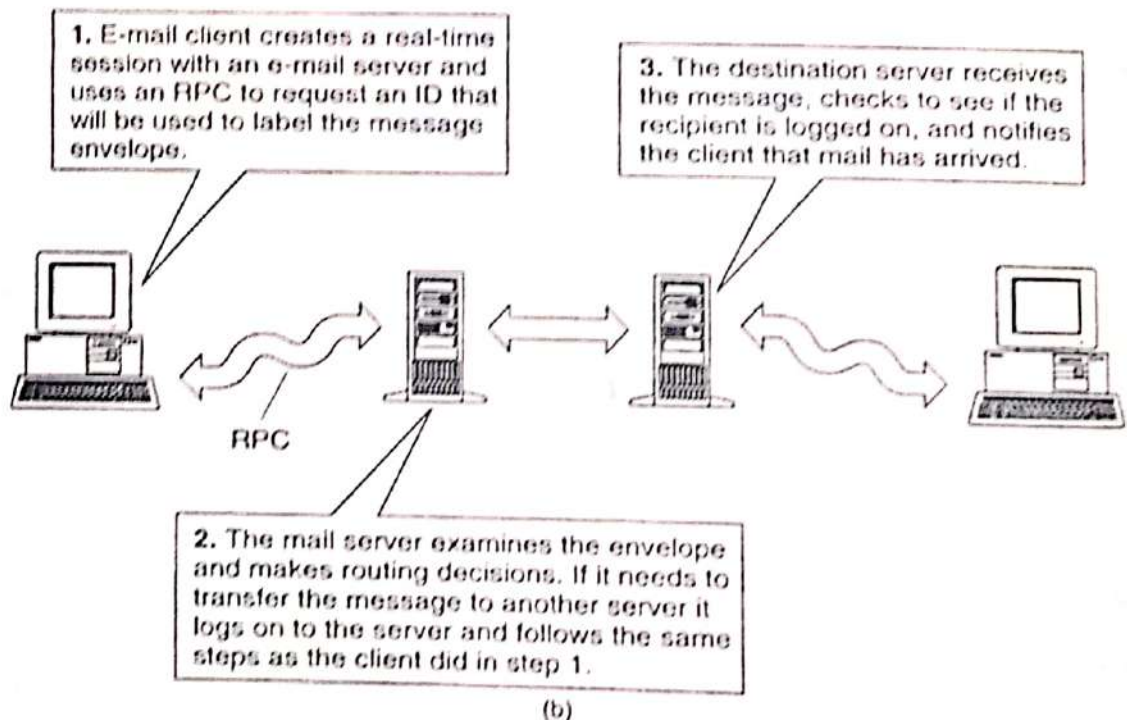
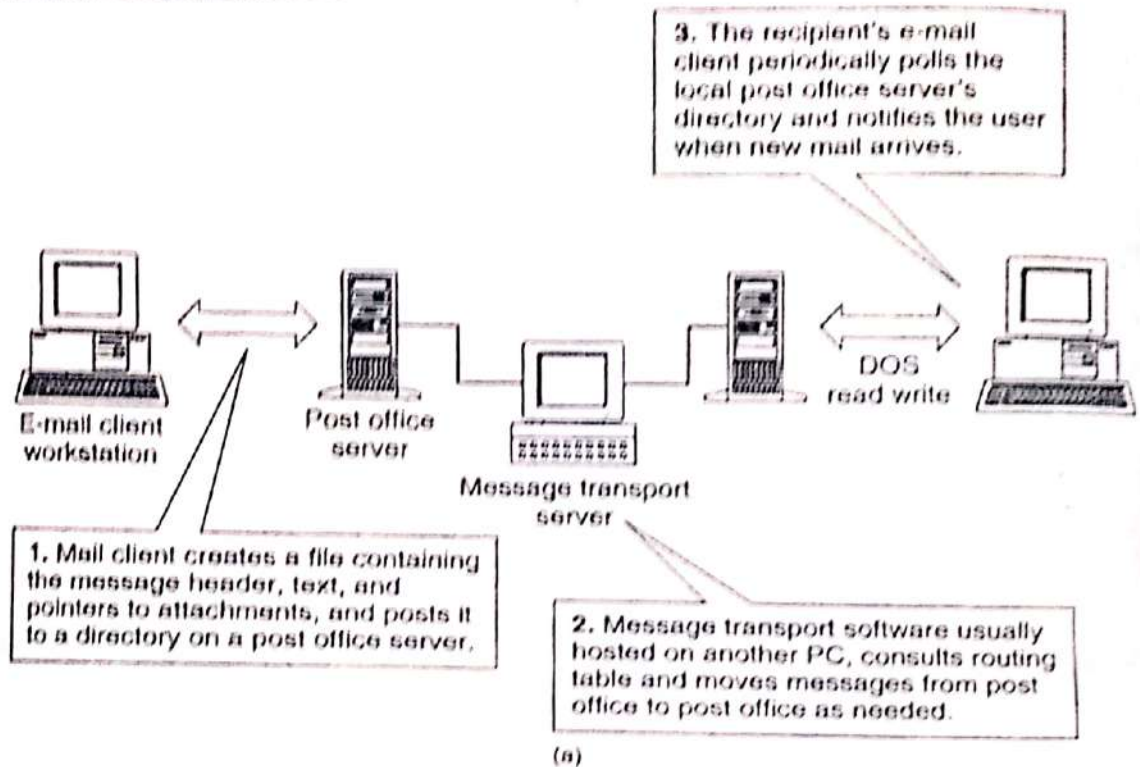
5. How Does E-mail Work

Figure 7.3 How e-mail works—three steps to mail delivery: (a) file-based systems; (b) client/server-based systems.

Figure depicts how e-mail works. Basically, two architectures are involved in

this diagram.

(i). A file-based system.

In this architecture, the mail client creates a file containing the message header, text, and pointers to attachments and posts it to a directory on a post office server.

Next, message-transport software, usually hosted on another PC, uses TCP/IP transport capabilities to route messages from post office to post office, as needed.

The recipient's e-mail client periodically polls the local post office server's directory and notifies the user when new mail arrives.

(ii) client/server architecture.

Here, the first step involves the e-mail client workstation creating a real-time session with an e-mail server and using a remote procedure call (RPC) to request an ID that will be used to label the message envelope.

Next, the mail server examines the envelope and makes routing decisions. If it needs to transfer the message to another server, it does. The destination server receives the message, checks to see if the recipient is logged on, and notifies the client that mail has arrived. Two basic components of an Internet e-mail message are: the header and the body.

The header requires the following lines:

Delivery-Date: This line shows the date and time the message was received in the mailbox.

Return-Path: This line shows the reply address of the original sender.

Received: Every entry in the header starting with Received represents a computer/gateway that has transferred the message, also referred to as a hop. If there are too many hops, the message will be bounced, or returned, to the original sender. A message will also bounce if the person is no longer found at that mail system.

Date : This line shows the date and time the message left the sender. This will vary by several seconds or minutes from the delivery date .

From : This line specifies the full name and e-mail address of the original sender.

Message – ID : This line serves as a unique identifier of each mail message. It includes the name of the machine sending the message, the date, time, and file name.

To: Each person receiving the message will appear on this line. If there is more than one address, the addresses will be separated by a comma. Some email systems may add these lines at the Internet gateway and may not be transparent to the sender.

Most e-mail systems will also add the following lines, even though they are not required; subject, content type and priority status.

Internet e-mail addresses are made up of two parts: the user name and domain name.

The user name is the account from which a message is sent.

Some systems use the person's last name, while others use an alias which shields the name from the recipient.

The domain name is an alphabetical mnemonic. Machines use the IP number assigned by the InterNIC to every machine or network connected to the internet. The InterNIC assigns and organizes domains and addresses maintains directories of Internet users, and provides information for connection to the internet.

A Special set of computers known as the Name server, uses DNS (Domain Naming System) to convert the domain name into the proper IP address. Other classical domain identifiers are :

.edu for educational institutions

.gov for federal governmental offices or organizations

.org for any other address that does not fall into the previous identifiers- usually non-profit organizations.

8. MIME: Multipurpose Internet Mail Extensions

MIME: Multipurpose Internet Mail Extensions
--

Nov – 10

Basic concepts

Multipurpose Internet Mail Extensions (MIME) (RFC-1521) provides Internet e-mail support for messages containing formatted text, sound images, video, and attachments.

MIME is backward-compatible with earlier SMTP messaging specifications and is easier to implement than ITU-T X.400. See the following list.

- Common way in which Binary files are sent as e-mail on the Internet.

- Content types are

1. Primary type—indicates general content of the material

2. Subtype—indicates the specific format

- Five basic primary MIME content-types are *text, image, audio, video, and application.*

- Composite MIME content types:

Message. One can send the message inside another message, labeling it *message/rfc822*. A MIME mailer can label each segment or part of the message as *message/partial*. The recipient's mail software can reassemble the message automatically.

Multipart. Allows more than one piece of MIME to be included in a message. Common examples of this use is *multipart/mixed* (there are multiple objects, each with its own content-type); *multipart/parallel* (objects should be viewed all at once, if possible); and *multipart/alternative*, (sends the same information in different formats, allowing the recipient to pick the best one.)

MIME encoding

Uses many different encoding methods, depending on the file type it is sending. content-transfer-encoding header on each message corresponding to the type of decoding the recipient needs to perform.

MIME software adopts the general philosophy of trying to work with existing non-MIME software as much as it possibly can.

Uses an encoding called base64 for pure binary files (similar to Bin-Hex and UUEncode).

The introduction of MIME means the Internet is well-positioned to carry multimedia messages containing content types as animated graphics, multimedia, and hypermedia.

These messages are exchanged using SMTP as the fundamental platform.3 MIME provides the ability to encapsulate different content types within the body of the message.

Before the initial June 1992 MIME specification, RFC-1351, the Internet was only able to transmit and receive ASCII type data.

If one wanted to send binary data, one had to first convert it to ASCII-type data

Before sending a graphic file such as a drawing or picture without MIME, one had to first run the graphic file through a UUEncode package and put the resultant ASCII-type output into the e-mail message

The recipient processed the file by running UUDecode to produce the original binary code for the graphic.

The Internet ensures that only messages less than 64 KB are transported through all gateways and systems.

If the graphic or multimedia file is larger than 64 KB, then UUEncode breaks it into 64-KB ASCII-encoded segments to be sent in multiple e-mail messages.

When all parts are received, the UUDecode reconstructs the original file from all the parts and decodes the message.

The most common method of ASCII to binary conversion up until now has been the UUencode/JUDecode facility, although MIME is quickly replacing it.

The RFC-1521 version of MIME (September 1993) added the ability of Internet e-mail to handle binary and text data, as well as multiple body parts without conversion to ASCII.

An Internet electronic mail message consists of two parts: **the headers and the body.**

The headers form a collection of field/value pairs structured according to RFC-822 (see Table 7.2), while the body, if structured, is defined according to MIME.

It is important to note that the basic MIME specification does not provide specific security protection: a MIME agent must include support for both the framework defined here and a mechanism to interact with a security protocol defined by some other mechanism (other RFCs).

The resulting combined service provides security for single-part and multipart textual and non textual messages.

TABLE 7.2 RFC-822 Message Envelope and Heading Fields

RFC MESSAGE field	Description
Autoforward	Address of the account that autoforwards the message.
BCC	Blind copy addressee(s). These are not known to the To or CC addresses.
CC	Carbon-copy addressee(s).
Comments	General remarks.
Date	Date message is sent.
Discarded-X400-IPMS extensions	Lost components after converting an X.400 message to an SMTP/RFC-822 message.
Encrypted	Indication that the message is encrypted.
Expiry date	Date the message is no longer valid.
From	Name and address of the originator of the message.
Importance	Importance of the rating given by the message sender. Choices are Urgent and Non-Urgent
In reply to	Message ID of the original message that this new message is in reply to.
Languages	Language in which the message is written.
Message Id	Unique message identifier.
Mime version	Indicates MIME body part type.
Obsoletes	Message id of message(s) no longer in use.
References	Other messages to which this one refers.
Reply by	Date by which a reply should be received.

Figure depicts the RFC-822 MIME transport envelope.

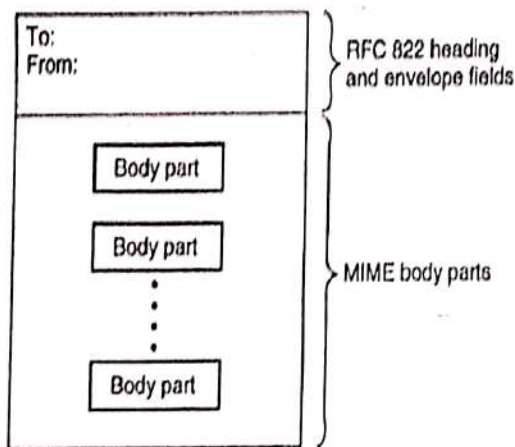


Figure 7.4 RFC-822 MIME transport envelope.

The multipart signed content type contains two body parts.

- The first body part is the *body part over which the digital signature was created*, including its MIME headers.
- The second body part contains the *control information* necessary to verify the digital signature.
- The first body part may contain any valid MIME content type, labeled accordingly.
- The second body part is labeled to the value of the protocol parameter; the attribute token for the protocol parameter is *protocol*.
- The value token is comprised of the *type* and *subtype* tokens of the *Content-Type:Jar* of the second body part (the *type* and *subtype* tokens are defined by the MIME specification).
- By registering new values for the required protocol parameter, the framework can be extended to accommodate a variety of protocols.
- The Message Integrity Check (MIC) is the name given to the quantity computed over the body part with a message digest or hash function, in support of the digital signature service.
- Valid value tokens are defined by the specification for the value of the protocol parameter.
- The value may be a comma (,) separated by a list of tokens, indicating the use of multiple MIC algorithms.
- The entire contents of the multipart/signed container must be treated as blind while it is in transit from an originator to a recipient. Intermediate message transfer agents

must not alter the content of a multipart/signed container in anyway, including changing the content transfer encoding of the body part or any of its encapsulated body

- The multipart/signed content type specifies how to support authentication and integrity services via digital signature. The control information is carried in the second of the two required body parts.

➤ When *creating a multipart/signed* body part, the following sequence of steps describes the processing necessary:

1. The content of the body part to be protected is prepared according to a local convention. The content is then transformed into a MIME body part in canonical MIME format, including an appropriate set of MIME headers.
2. The body part (headers and content) to be digitally signed is prepared for signature according to the value of the protocol parameter. The MIME headers of the signed body part are included in the signature to protect the integrity of the MIME labeling of the data that is signed.
3. The prepared body part is made available to the signature creation process according to a local convention. The signature creation process must make available to a MIME implementation two data streams: the control information necessary to verify the signature, which the MIME implementation will place in the second body part and label according to the value of the protocol parameter, and the digitally signed body part, which the MIME implementation will use as the first body part.

When *receiving a multipart/signed* body part, the following sequence of steps describes the processing necessary to verify the signature or signatures.

1. The first body part and the control information in the second body part must be prepared for the signature verification process according to the value of the protocol parameter.
2. The prepared body parts must be made available to the signature verification process according to a local convention. The signature verification process must make available to the MIME implementation the result of the signature verification and the body part that was digitally signed.
3. The result of the signature verification process is made available to the user and the MIME implementation continues processing with the verified body part.

The multipart/encrypted content type specifies how to support confidentiality via encryption. The control information is carried in the first of the two required body parts.

The first body part contains the control information necessary to decrypt the data in the second body part and is labeled according to the value of the protocol parameter.

The second body part contains the data that was encrypted and is always labeled application/octet stream A three-step process is described for the origination and reception of the multipart/encrypted contents.

The details of the processing performed during each step is left to be specified by the security protocol being used

When *creating a multipart) encrypted* body part, the following sequence of steps describes the processing required.

1. The contents of the body part to be protected are prepared according to a local convention. The contents are then transformed into a MIME body part in canonical MIME format, including the appropriate set of MIME headers.
2. The body part (*headers* and content) to be encrypted is prepared for encryption according to the value of the protocol parameter. The MIME headers of the encrypted body part are included in the encryption to protect from disclosure the MIME labeling of the data that is encrypted.
3. The prepared body part is made available to the encryption process according to a local convention. The encryption process must make available to a MIME implementation two data streams: the control information necessary to decrypt the body part, which the MIME implementation will place in the first body part and label according to the value of the protocol parameter, and the encrypted body part, which the MIME implementation will place in the second body part and label application/octet-stream. Thus, when used in a multipart/encrypted, the application/octet-stream data is comprised of a nested MIME body part.

When *receiving a multipart/encrypted* body part, the following sequence of steps describes the processing necessary to decrypt the enclosed data.

1. The second body part and the control information in the first body part must be prepared for the decryption process according to the value of the protocol parameter.

2. The prepared body parts must be made available to the decryption process according to a local convention. The decryption process must make available to the MIME implementation the result of the decryption and the decrypted form of the encrypted body part.

Note: The result of the decryption process is likely to include a testament of the success or failure of the decryption. Failure may be due to an inability to locate the proper decryption key or the proper recipient field. Any data of a failed decryption process is considered garbled information.

3. The result of the decryption process is made available to the user and the MIME implementation continues processing with the decrypted body part.
Note: A MIME implementation will not be able to display the received form of the second body part because the application of encryption will transform the body part. This transformation will be described in the content of the first body part.
- MIME body parts**

As previously noted, MIME provides a multiple body part architecture used by SMTP to transport binary and text code within the same message. It does not get around the 64-KB limit, which is a transport limit, based on the total size of the message.

Messages larger in size than 64 KB are transmitted in separate 64 KB segments, which the system then reassembles.

Boundary strings are used to separate body parts.

These strings are unique over the entire message and are defined on a message by message basis. Each is on a line by itself, starting with "--" (two hyphens) and ending with end-of-line characters such as a carriage return. This string of characters would not appear anywhere in the bodies of the messages.

MIME specifications currently support seven body types:

- text,
- multipart,
- application,
- message,
- image,
- audio, and
- video.

Support for the various types, which is described next, enables the Internet to carry larger and more complex messages in support of multimedia messaging.

Text. The text body part enables a message to contain simple message data such as ASCII and can be transported using the current 7-bit ASCII strings used on Internet. This is the most rudimentary form of message content specified within MIME. It may also contain other subtype text strings known as **plain**, or **unembellished**, text and **rich text**.

The rich text subtype is used to handle simple text format protocols that support boldfacing, italicizing, indenting, and so on.

Standard Generalized Markup Language (SGML) is an international standard that separates a document into discrete, structured parts so that the document can be revised in different computer environments. Currently, two categories of character sets are supported: CharseU5ASCJJ and 150-8859-1 through ISO-8859-9.

Multipart. The multipart body part consists of several body parts containing unrelated data. MIME permits the user to break the content down into subtypes. The four initial subtypes are mixed, alternative, parallel, and digest. Only 7-bit, 8-bit, or binary may be used for multipart

content type encoding. If other encoding is required, each body part will specify that encoding in its header.

Mixed. The mixed multiple body part subtype is the most frequently used; it ensures that a number of very different message content types, such as text, graphics, or images, can be transmitted in the same message.

Alternative. This subtype presents the same data in different formats, such as a word processing document in three representations such as ASCII, Word for Windows, and Word Perfect.

Parallel. This subtype contains body parts that must be viewed at the same time. This type is useful when documents are linked with a utility such as hypertext.

Digest. This subtype is used when all the body parts are messages in their own right. It is important that an e-mail gateway interpret that the message body is a nested message as opposed to a video image or graphic, because the gateway has to handle each body part differently.

Message. A message body part contains other messages, such as forwarded or transferred messages. It is the most basic body part in MIME, and its subtypes are as follows:

RFC-822. This subtype is the specification for a complete standard Internet e-mail message and is the primary and most frequently used subtype for this content type.

Partial. This subtype allows messages to be sent in parts through the e-mail network. This is necessary when the message has exceeded the 64-KB limit imposed by the Internet transport system.

External-Body. This subtype is for specifying larger data files, such as text, video, audio, or others that are not contained within the message. The body parts reference the location of the data on mail servers or anonymous FTP servers. File Transfer Protocol (FTP) servers permit any user to locate and download a file to their own computer.

Image. The image body part contains time varying images or images that contain movement-like motion pictures and full motion video.

The current subtypes are

MPEG. Motion Picture Experts Group (MPEG) is the standard for digitally compressing movies.

GIF CompuServe's Graphic Image Format.

Audio. The audio body part contains sound data such as voice or music. The basic subtype indicates 8-bit, Integrated Services Digital Network (ISDN), or μ -law encoding, with a sample rate of 8000 Hz.

Application. Application body parts, generated from computer application programs, contain spreadsheets, calendar information, word processing documents, and presentation formats such as Word Perfect or Microsoft Word. Its current subtypes are as follows:

Octet-stream. This subtype is used for binary data that does not need or have an interpreter.

ODA. This subtype is the Office Document Architecture as defined by the International Communications Union.

Postscript. This subtype is defined by Adobe Systems and supports high-quality postscript printer output. This subtype should not be used with non printer interpreters because the information contained in a postscript file is so rich that sending this format may give the receiver information about the sender's access to files and other rights.

9.S/MIME: Secure Multipurpose Internet Mail Extension

Secure e-mail system, the message would be like a letter in a sealed envelop. The specifications, Secure/Multipurpose Internet Mail Extensions(S/MIME) allows vendor to independently develop interoperable RSA-based security for various e-mail platform. S/MIME message composed & encrypted on one's vendors application can be decrypted on another.

S/MIME, add security to email message in MIME format security offered are AUTHENTICATION (using digital signature) & PRIVACY (using encryption).

What is S/MIME? It is a specification for secure e-mail

Why S/MIME? Proven cryptographic constructs with standard e-mail practices. It was designed to be interoperable, so two package that implement S/MIME can communicate securely.

What cryptographic algorithm does S/MIME use? It uses a hybrid approach to providing security, often referred to as DIGITAL ENVELOPE.

Bulk message encryption done with symmetric cipher & public key algorithm used for key exchange.

S/MIME recommends 3 symmetric encryption algorithm: DES, TRIPLE-DES & RC2.

What are PKCS, particularly PKCS7 & PKCS10?

PKCS is a set of standards for implementation of public key cryptography (RSA)

PKCS7 is flexible 7 extensible message format for representing results of cryptographic operation on some data.

PKCS10 is message syntax for certification requests.

Does S/MIME use digital certificate?

X.509 format standard for digital certificate.

10.MOSS: MESSAGE OBJECT SECURITY SERVICES

Explain MOSS in detail.

(15) (Nov '09)

- MOSS is based in large part on the PEM protocol as defined by RFC 1421.

- Many of PEMs features and most of its protocol specification are included here. In order to make use of the MOSS services, a user (where user is not limited to being a human, e.g., it could be a process or a role) is required to have at least one public/private key pair.
- The public key must be made available to other users with whom secure communication is desired. The private key must not be disclosed to any other user.
- An originator's private key is used to digitally sign MIME objects; a recipient would use the originator's public key to verify the digital signature.
- A recipient's public key is used to encrypt the data encrypting key that is used to encrypt the MIME object; a recipient would use the corresponding private key to decrypt the data encrypting key so that the MIME object can be decrypted.
- As long as the private keys are protected from disclosure, i.e., the private keys are accessible only to the user to whom they have been assigned, the recipient of a digitally signed message will know from whom the message was sent and the originator of an encrypted message will know that only the intended recipient is able to read it.
- For assurance, the ownership of the public keys used in verifying digital signatures and encrypting messages should be verified. A stored public key should be protected from modification.

APPLICATION OF MIME OBJECT SECURITY SERVICES

The application of the MOSS digital signature service requires the following components.

- (1) The data to be signed.
- (2) The private key of the originator.

The data to be signed is prepared according to the description below.

The digital signature is created by generating a hash of the data and encrypting the hash value with the private key of the originator.

The digital signature, some additional ancillary information described below, and the data are then embodied in a multipart/signed body part. Finally, the multipart/signed body part may be transferred to a recipient or processed further, for example, it may be encrypted.

The application of the MOSS encryption service requires the following components.

- (1) The data to be encrypted.
- (2) A data encrypting key to encrypt the data.
- (3) The public key of the recipient.

The data to be encrypted is prepared according to the description below. The originator creates a data encrypting key and encrypts the data. The recipient's public key is used to encrypt the data encrypting key.

The encrypted data, the encrypted data encrypting key, and some additional ancillary information described below are then embodied in a multipart/encrypted body part, ready to be transferred to a recipient or processed further, for example, it may be signed.

DEFINITION OF SECURITY SUBTYPES OF MULTIPART

The multipart/signed content type specifies how to support authentication and integrity services via digital signature. The control information is carried in the second of the two required body parts.

The multipart/encrypted content type specifies how to support confidentiality via encryption. The control information is carried in the first of the two required body parts.

A three-step process is described for the origination and reception of the multipart/signed and multipart/encrypted contents. The details of the processing performed during each step is left to be specified by the security protocol being used.

Definition of Multipart/Signed

- (1) MIME type name: multipart
- (2) MIME subtype name: signed
- (3) Required parameters: boundary, protocol, and micalg
- (4) Optional parameters: none
- (5) Security considerations: Must be treated as opaque while in Transit

The multipart/signed content type contains exactly two body parts.

The first body part is the body part over which the digital signature was created, including its MIME headers.

The second body part contains the control information necessary to verify the digital signature.

The first body part may contain any valid MIME content type, labeled accordingly.

The second body part is labeled according to the value of the protocol parameter.

The attribute token for the protocol parameter is "protocol", i.e., parameter := "protocol" "=" value

The value token is comprised of the type and sub-type tokens of the Content-Type: header of the second body part, i.e., value := <"> type "/" subtype <"> where the type and subtype tokens are defined by the MIME specification. The semantics of the protocol parameter are defined according to its value.

The attribute token for the micalg parameter is "micalg", i.e., parameter := "micalg" "=" value.

The Message Integrity Check (MIC) is the name given to the quantity computed over the body part with a message digest or hash function, in support of the digital signature service. Valid value tokens are defined by the specification for the value of the protocol parameter.

The value may be a comma (",") separated list of tokens, indicating the use of multiple MIC algorithms. As a result, the comma (",") character is explicitly excluded from the list of characters that may be included in a token used as a value of the micalg parameter.

If multiple MIC algorithms are specified, the purpose and use of the multiple algorithms is defined by the protocol. If the MIC algorithm is also specified in the control information and the value there does not agree with the value in this parameter, it must be treated as an error.

NOTE: The presence of the micalg parameter on the multipart/signed content type header is explicitly intended to support one-pass processing. MIME implementations may locate the second body part by inputting the first body part and computing the specified MIC values until the boundary identifying the second body part is found.

The entire contents of the multipart/signed container must be treated as opaque while it is in transit from an originator to a recipient.

Intermediate message transfer agents must not alter the content of a multipart/signed in any way, including, but not limited to, changing the content transfer encoding of the body part or any of its encapsulated body parts.

The signature in a multipart/signed only applies to the material that is actually within the multipart/signed object. In particular, it does not apply to any enclosing message material, nor does it apply to entities that are referenced (e.g. via a MIME message/external body) by rather than included in the signed content.

When creating a multipart/signed body part, the following sequence of steps describes the processing necessary. It must be emphasized that- these steps are descriptive, not prescriptive, and in no way impose restrictions or requirements on implementations of this specification.

(1) The content of the body part to be protected is prepared according to a local convention. The content is then transformed into a MIME body part in canonical MIME format, including an appropriate set of MIME headers.

In addition, if the multipart/signed object is EVER to be transferred over the standard Internet SMTP infrastructure, the resulting MIME body is constrained to 7 bits that is, the use of material requiring either 8bit or binary content-transfer-encoding is NOT allowed.

Such 8 bit or binary material MUST be encoded using either the quoted-printable or base64 encodings. This requirement exists because it is not generally possible, given the current characteristics of Internet SMTP, for a message originator to guarantee that a message will travel only along paths capable of carrying 8bit or binary material. SMTP clients normally have the option of either converting the message to eliminate the use of 8bit or binary encoding or returning a non delivery notification to the originator. However, conversion is not viable in the case of signed objects since conversion would necessarily invalidate the signature. This leaves a non delivery notification as the only available option, which is not acceptable.

(2) The body part (headers and content) to be digitally signed is prepared for signature according to the value of the protocol parameter. The MIME headers of the signed body part are included in the signature to protect the integrity of the MIME labeling of the data that is signed.

(3) The prepared body part is made available to the signature creation process according to a local convention. The signature creation process must make available to a MIME implementation two data streams: the control information necessary to verify the signature, which the MIME implementation will place in the second body part and label according to the value of the protocol parameter, and the digitally signed body part, which the MIME implementation will use as the first body part.

When receiving a multipart/signed body part, the following sequence of steps describes the processing necessary to verify the signature or signatures. It must be

emphasized that these steps are descriptive, not prescriptive, and in no way impose restrictions or requirements on implementations of this specification.

(1) The first body part and the control information in the second body part must be prepared for the signature verification process according to the value of the protocol parameter.

(2) The prepared body parts must be made available to the signature verification process according to a local convention. The signature verification process must make available to the MIME implementation the result of the signature verification and the body part that was digitally signed.

Explain about Pretty Good Privacy (PGP) in detail.

(15) Dec '08

Pretty Good Privacy (PGP) is a public key encryption system.

PGP uses the RSA (Rivest, Shamir, and Adleman) public-key cryptosystem.

PGP supports the following functions :

- Generates public/private RSA keys.
- Encrypts messages to be transmitted using the destination's public key
- Decrypts messages received using the recipient's private key
- Authentication messages with digital signatures
- Manages key rings that keep track of destination's public keys

Phil Zimmermann wrote the first finished version of PGP in 1991.

It was made publicly available on the internet as freeware.

Zimmermann had no license for the RSA patents on public-key cryptography.

All encryption systems' security is based on a cryptographic key or the key to the cryptography's electronic lock.

Private key encryption systems, or conventional cryptography, use a single or private key. This private key is used for both encryption and decryption.

The sender and recipient of the mail message must share the same key.

Public-key systems generate two mathematically related keys.

A message encrypted with one key can be decrypted only with the other.

Cryptography is the science of using mathematics to hide or code the meaning of messages.